

网络安全——

网络攻击——DNS威胁与防范

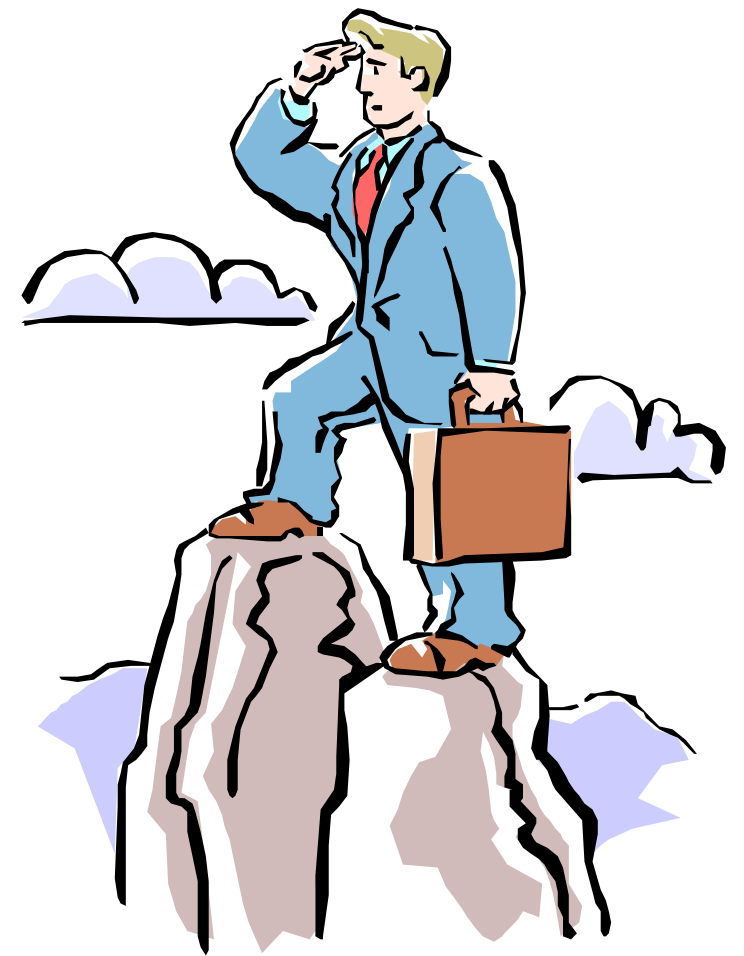
北京邮电大学 网络空间安全学院

武斌

目录

学习完本次课程，您应该能够了解：

- DNS概述
- DNS协议
- DNS工作流程
- DNS安全威胁
- DNS安全防范



DNS安全威胁及防范

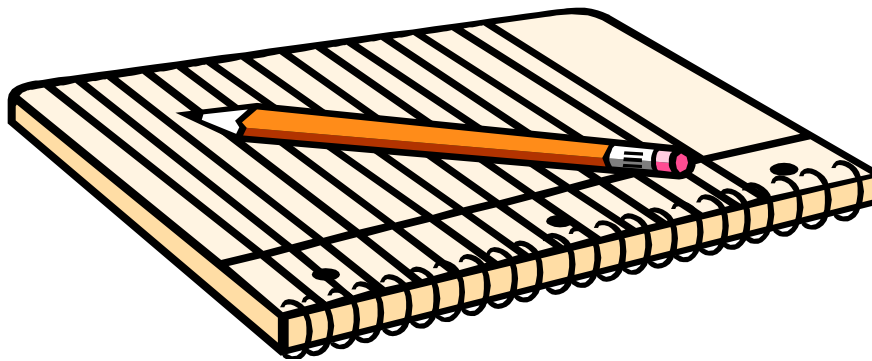
● DNS概述

● DNS工作流程

● DNS协议

● DNS安全威胁

● DNS安全防范



DNS 概述

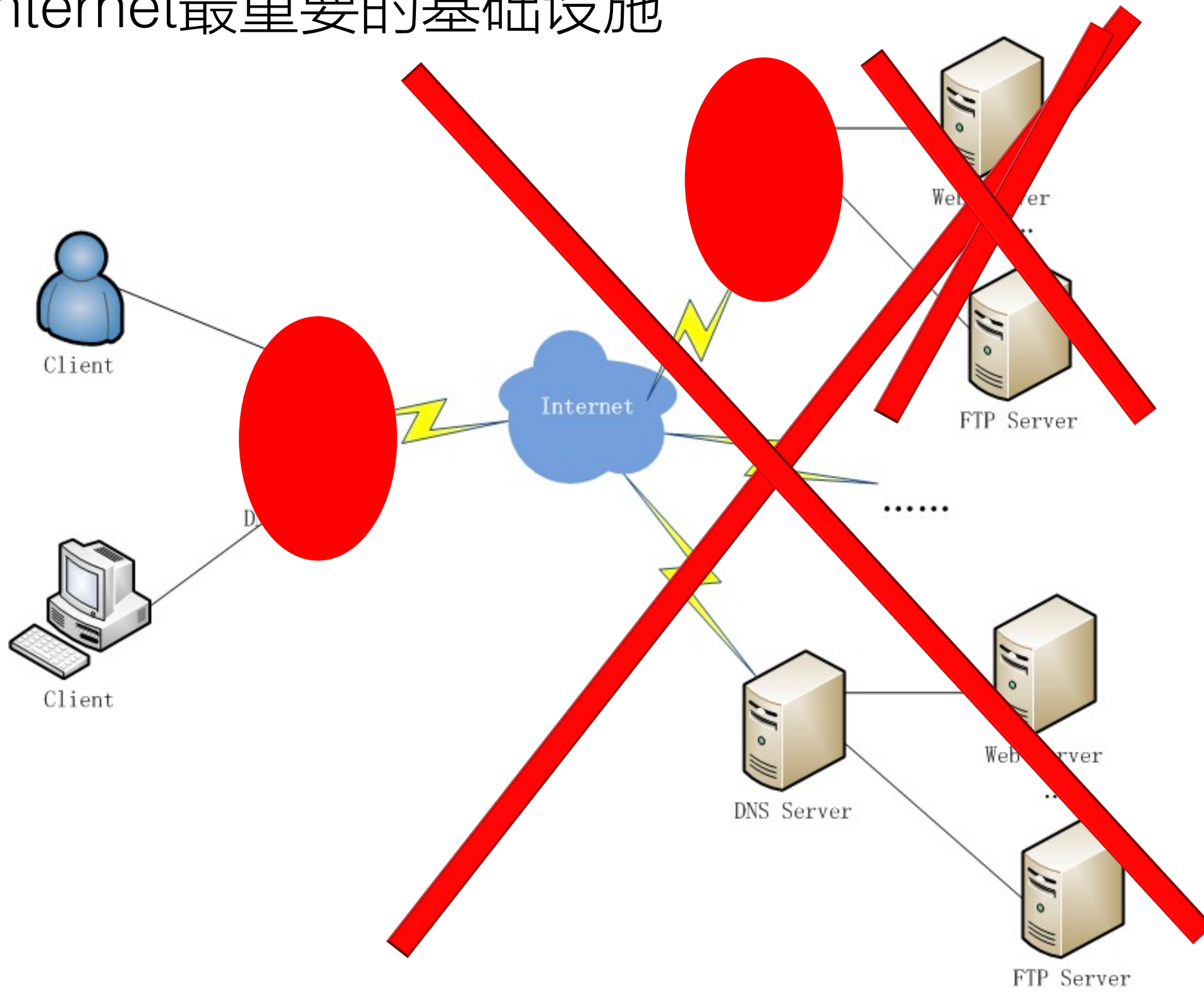
- 域名系统 (Domain Name System , DNS)在互联网上具有举足轻重的作用，负责**在域名和IP地址之间进行转换**。
- 通常在互联网上使用的都是域名，比如北邮人论坛为 bbs.byr.cn，而计算机在通信时使用的是其对应的IP地址:114.255.40.86。
- 可以想象，如果负责域名转换的域名服务器有问题，那么将直接导致互联网用户无法使用域名来访问互联网，除非用户能够记住大量的IP地址。

什么是DNS?

- **域名系统 (Domain Name System , DNS)**
- **负责在域名和IP地址之间进行转换**
- **是Internet中最重要
的基础设施**
- The Domain Name System (DNS) is a **hierarchical distributed naming system** for computers, services, or any resource connected to the Internet or a private network.
- It associates various information with domain names assigned to each of the participating entities.
- Most prominently, it translates domain names, which can be easily memorized by humans, to the numerical IP addresses needed for the purpose of computer services and devices worldwide.

DNS概述

- Internet最重要的基础设施



DNS概述

- 早在ARPANET时代，整个网络上只有数百台计算机，那时使用一个**Hosts文件**，列出所有主机的名字和相应的IP地址。只要用户输入一个主机的名字，计算机就能很快的将这个主机名字解析成机器能够识别的二进制IP地址。
- 虽然从理论上讲，可以只使用**一个名称服务器**，使它装入因特网上所有的主机名，并回答所有对IP地址的查询，但是随着网络的扩大，这样的域名服务器肯定会因过负荷而无法正常工作，而且一旦该域名服务器出现故障，整个网络就会瘫痪。

DNS 概述

- DNS最早于1983年由[保罗·莫卡派乔斯](#)（ Paul Mockapetris ）发明；原始的技术规范在882号[因特网标准草案](#)（ [RFC 882](#) ）中发布。
- 1987年发布的**第1034和1035号**草案修正了DNS技术规范，并废除了之前的第882和883号草案。在此之后对因特网标准草案的修改基本上没有涉及到DNS技术规范部分的改动。

DNS概述

- 因特网的**域名系统**被设计成为一个**联机分布式数据库系统**，并采用客户服务器方式运行。
- DNS使用的大多数名字都可在本地解析，仅有少量解析需要在因特网上通信，因此系统效率很高。
- 由于DNS是分布式系统，即使单个计算机出现故障，也不会妨碍整个系统的运行。

DNS概述

- 因特网域名系统采用**层次树状结构**的命名方法，任何一个连接到因特网的主机或路由器都有一个**唯一的层次结构的**名字****，即域名（Domain Name）。这里，“域”是名字空间中的一个可被管理的划分。域还可以继续划分为子域，如：二级域、三级域等。
- 域名结构由若干分量组成，各分量之间用点隔开，如：
 - ▪ ▪ . **三级域名. 二级域名. 顶级域名**

DNS概述

- 早期的域名必须以英文句号.结尾。
- 例如：http://www.wikipedia.org.这样DNS才能够进行域名解析。如今DNS服务器已经可以自动补上结尾的句号。
- **各分量代表不同级别的域名**，每一级域名都由英文字母和数字组成，不区分大小写。
- 域名系统既不规定一个域名需要包含多少个下级域名，也不规定每一级域名代表什么意思。
- 各级域名由其上一级域名管理机构管理。
- **域名与URL的关系？**

<https://xueshu.baidu.com/usercenter/index/category>

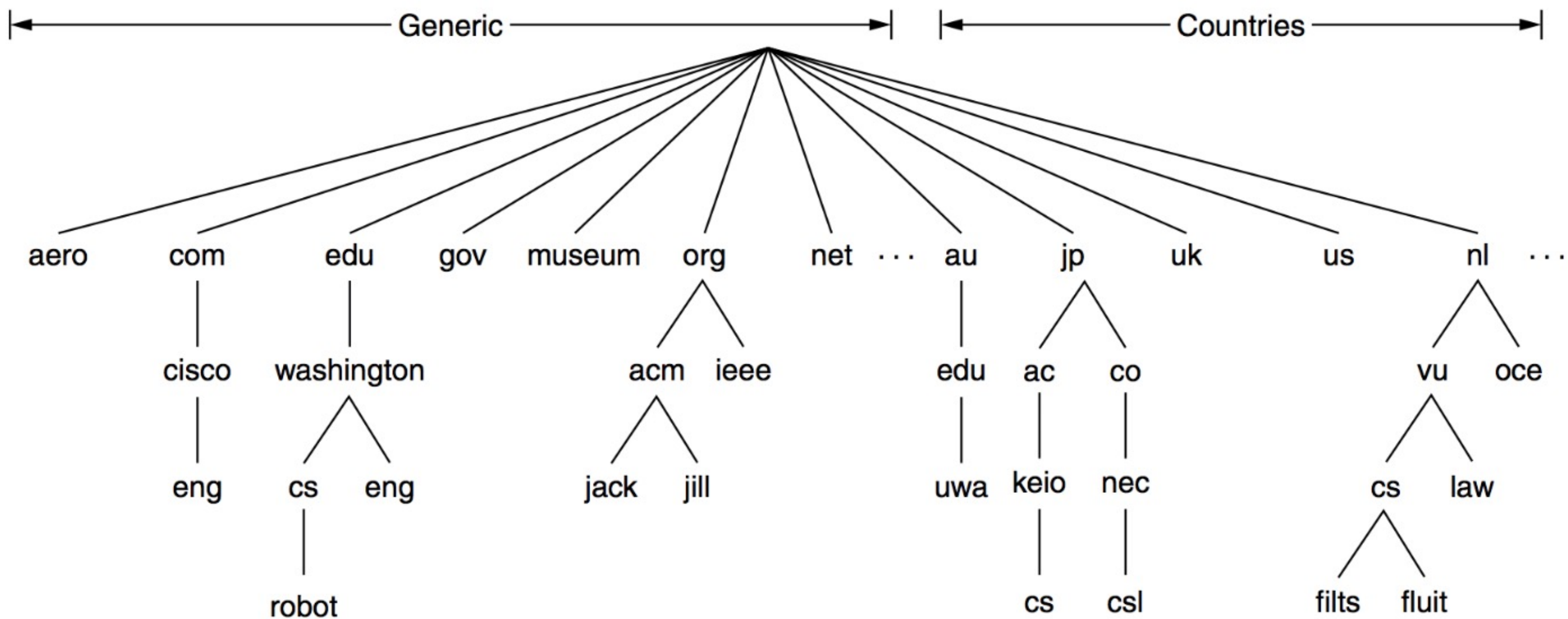
域名、主机名与URL例子

<http://mail.163.com/index.html>

- 1) http://: 这个协议，也就是HTTP超文本传输协议，也就是网页在网上传输的协议。
- 2) mail: 这个服务器名，代表着是一个邮箱服务器，所以是mail.
- 3) 163.com: 这个域名，是用来定位网站的独一无二的名字。
- 4) mail.163.com: 这个是网站名（主机名），由服务器名+域名组成。
- 5) /: 这个根目录，也就是说，通过网站名找到服务器，然后在服务器存放网页的根目录
- 6) index.html: 这个是根目录下的默认网页
- 7) <http://mail.163.com/index.html>: **URL，统一资源定位符**，全球性地址，用于定位网上的资源。

www.163.com，域名是163.com，建立一个www服务器

DNS概述

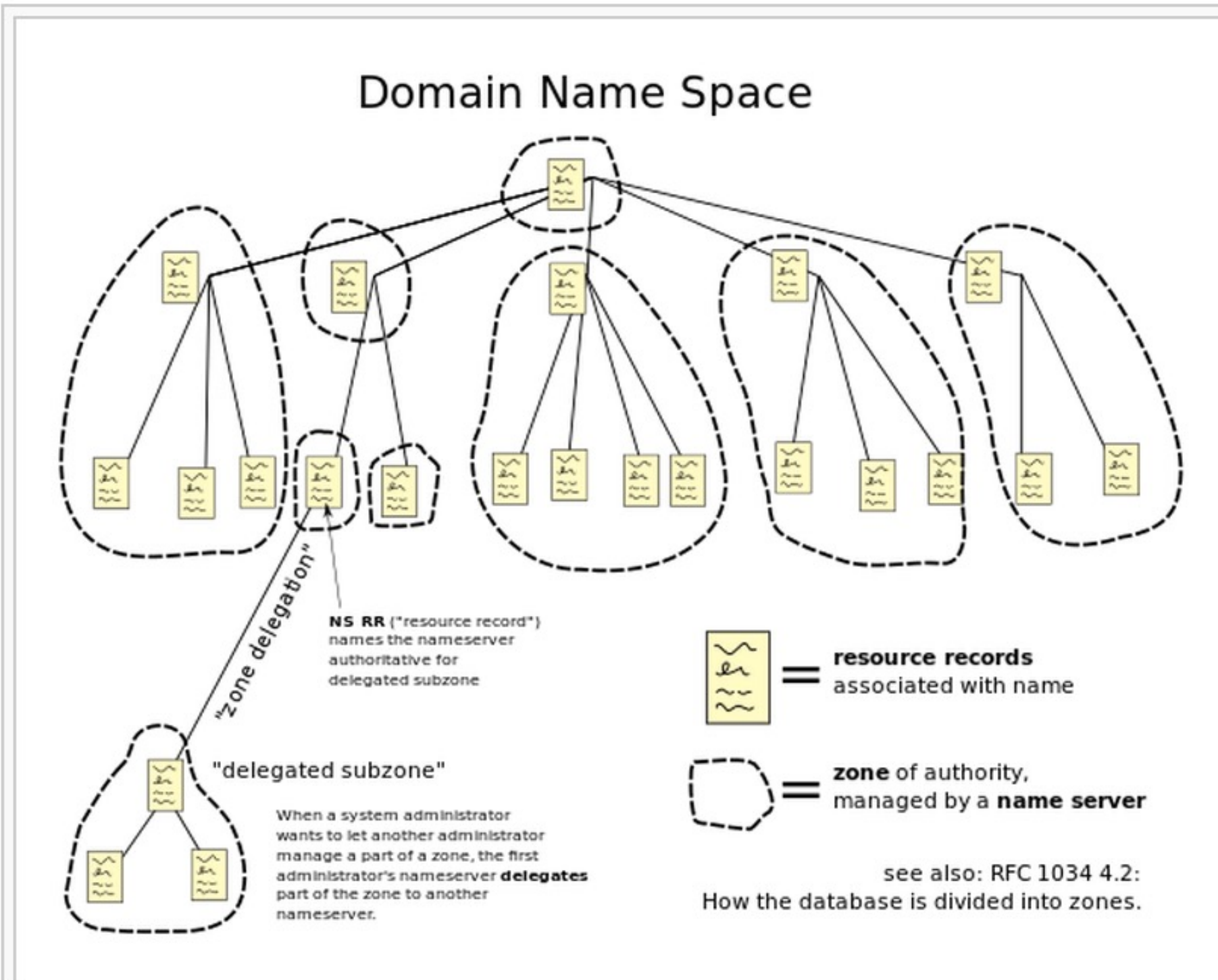


域名空间树

DNS概述

- 通用顶级域名 (gTLD)
 - .com/.net/.org/.edu/.gov/.mil/.int
 - .cn
 - .mobi
 - .asia
 - .biz(new)
 - .info(new)
 - .name(new)
 - .cc, .tv, .sh, .hk
- 基于984个全球范围的“根域名服务器”（分成13组，分别编号为A至M）。从这984个根服务器开始，余下的Internet DNS名字空间被委托给其他的DNS服务器，这些服务器提供DNS名称空间中的特定部分。

Domain Name Space



The hierarchical Domain Name System, organized into zones,
each served by a name server



DNS 资源记录

域名资源记录

理论上对于每一个域名我们只需要在域名服务器上保存一条记录即可。这里的记录一般叫作**域名资源记录**，它是一个**五元组**，可以用以下格式表示：

Domain_name	Time_to_live	Class	Type	Value
--------------------	---------------------	--------------	-------------	--------------

其中：

- 1.Domain_name: 指出这条记录适用于哪个域名；
- 2.Time_to_live: 用来表明记录的生存周期，也就是说最多可以缓存该记录多长时间（后面会讲到缓存机制）；
- 3.Class: 一般总是IN；
- 4.Type: 记录的类型；
- 5.Value: 记录的值，如果是A记录，则value是一个IPv4地址。

DNS 资源记录

域名资源记录类型

记录类型	含义
A	主机的IPv4地址
AAAA	主机的IPv6地址
NS	该域名所在域的权威域名服务器
MX	接受特定域名电子邮件的服务器域名
CNAME	当前域名的一个别名

DNS常用命令 (Windows)

- Ipconfig/all

查看网络配置情况，包括DNS服务器IP。

- Ipconfig /flushdns

清除DNS缓存

- Ipconfig /displaydns

查看DNS缓存

- Nslookup

查看DNS解析结果

WHOIS的概念

- “WHOIS”是当前域名系统中不可或缺的一项信息服务。
- 很多用户希望进一步了解域名、名字服务器的详细信息，这就会用到WHOIS。
- 对于域名的注册服务机构（ registrar ）而言，要确认域名数据是否已经正确注册到域名注册中心（ registry ），也经常会用到WHOIS。
- 直观来看，WHOIS就是**链接到域名数据库的搜索引擎**，一般来说是属于网络信息中心（ NIC ）所提供和维护的名字服务之一。

WHOIS的概念

- WHOIS系统是一个Client/Server系统，Server端默认监听43号TCP端口，接收查询请求并产生响应。
- 在ARPANet时代，域名信息就备受网络用户的关注。
- 斯坦福研究院（Stanford Research Institute，SRI）在20世纪80年代初行使着网络信息中心（Network Information Center，NIC）的职责，着手建立WHOIS系统，并将其工作成果提交给IETF。经过改进和修改，NICNAME/WHOIS理论得以进一步完善，成为Internet上的标准服务之一。

WHOIS的概念

- 这以后几乎所有的UNIX版本都将WHOIS作为TCP/IP协议栈中的上层应用协议，并实现了著名的客户端程序WHOIS。
- **中国互联网络信息中心**(China Internet Network Information Center，简称CNNIC)是经我国主管部门批准授权，行使我国国家互联网络信息中心职责的管理和服务机构。
- 作为我国的域名体系注册管理机构，CNNIC也提供了所辖范围内域名信息查询的WHOIS服务。

WHOIS的概念

- 互联网名称与数字地址分配机构 (The Internet Corporation for Assigne- Names an- Numbers , ICANN) 是[美国加利福尼亚](#)的非营利社团，主要由[互联网协会](#)的成员组成，成立于1998年10月，目的是接管包括管理[域名](#)和[IP地址](#)的分配等与[互联网](#)相关的任务
- 负责互联网协议 (IP) 地址的空间分配、协议标识符的指派、通用顶级域名 (gTLD) 以及国家和地区顶级域名 (ccTLD) 系统的管理、以及根服务器系统的管理。

Registrar Data

We will display stored WHOIS data for up to 30 days.

 refresh Make Private Now

Domain Name: alibaba.com
Registry Domain ID: 5435352_DOMAIN_COM-VRSN
Registrar WHOIS Server: grs-whois.hichina.com
Registrar URL: http://whois.aliyun.com
Updated Date: 2018-11-19T04:52:41Z
Creation Date: 1999-04-15T04:00:00Z
Registrar Registration Expiration Date: 2023-05-23T19:54:58Z
Registrar: Alibaba Cloud Computing (Beijing) Co., Ltd.
Registrar IANA ID: 420
Reseller:
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: serverDeleteProhibited https://icann.org/epp#serverDeleteProhibited
Domain Status: serverTransferProhibited https://icann.org/epp#serverTransferProhibited
Domain Status: serverUpdateProhibited https://icann.org/epp#serverUpdateProhibited
Registrant City:
Registrant State/Province: zhe jiang
Registry Registrant ID: Not Available From Registry
Name Server: NS1.ALIBABADNS.COM
Name Server: NS2.ALIBABADNS.COM
DNSSEC: unsigned
Registrar Abuse Contact Email: DomainAbuse@service.aliyun.com
Registrar Abuse Contact Phone: +86.95187
URL of the ICANN WHOIS Data Problem Reporting System: http://wdprs.internic.net/
>>>Last update of WHOIS database: 2019-10-24T21:52:18Z <<<

For more information on Whois status codes, please visit https://icann.org/whois/statuscodes

Important Reminder: Per ICANN 2013RAA's request, Hichina has modified the WHOIS data for .COM domains.

Information Updated: 2019-10-25 18:26:25

Suggested Domains for alibaba.com

Get a \$7.99 .COM domain with promo code
NAME799Find the perfect domain at
name.com

DNS安全威胁及防范

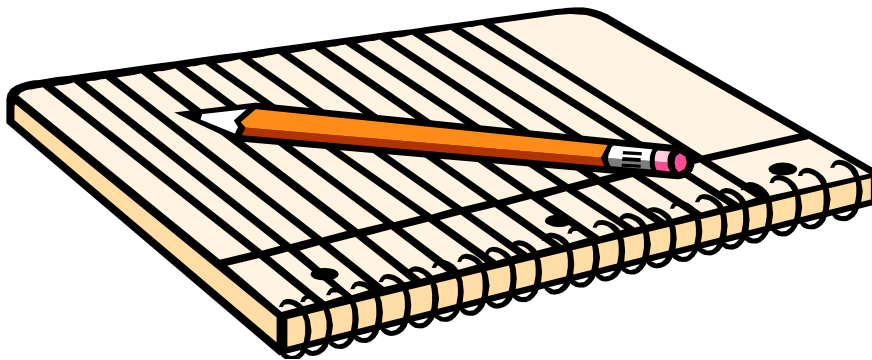
● DNS概述

● DNS工作流程

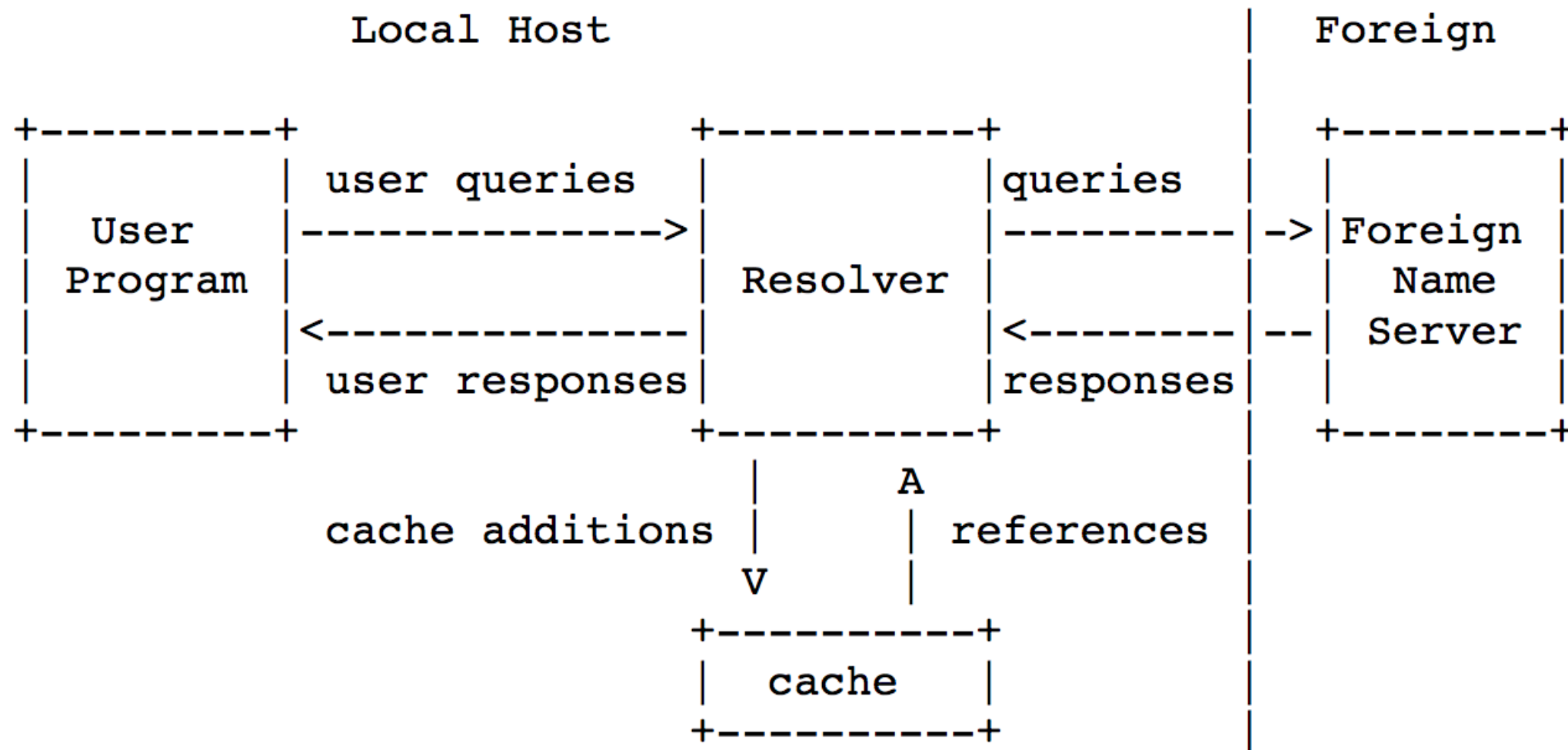
● DNS协议

● DNS安全威胁

● DNS安全防范

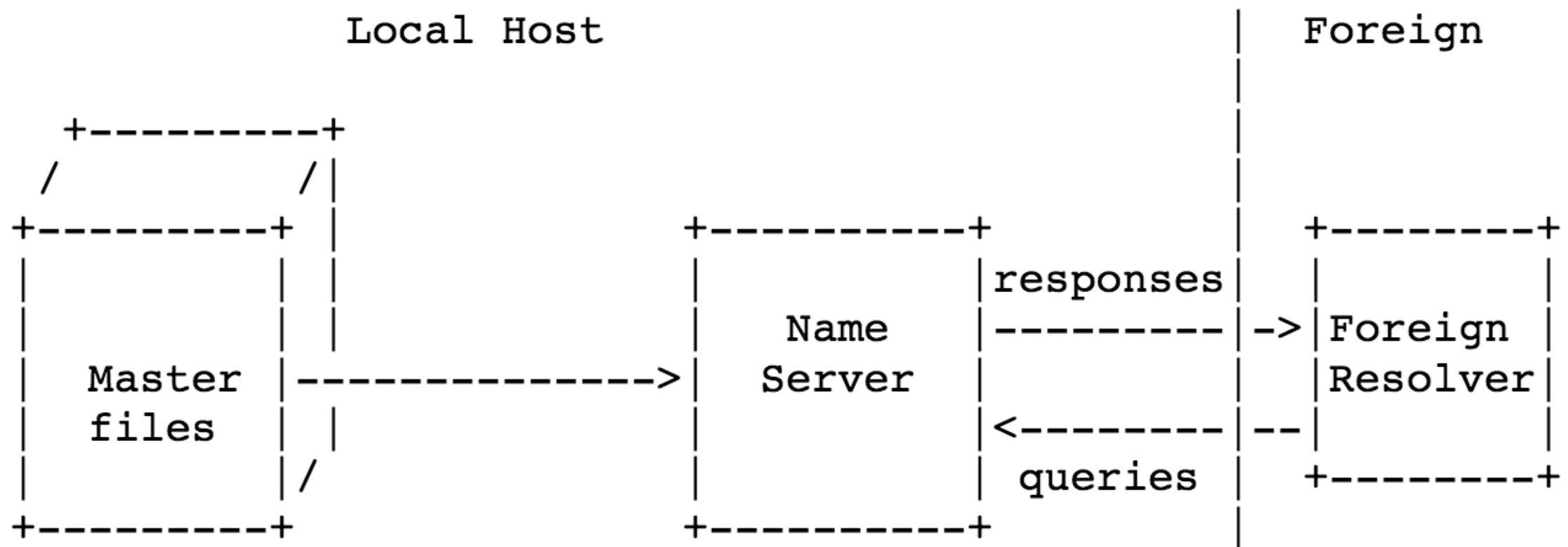


DNS 工作流程



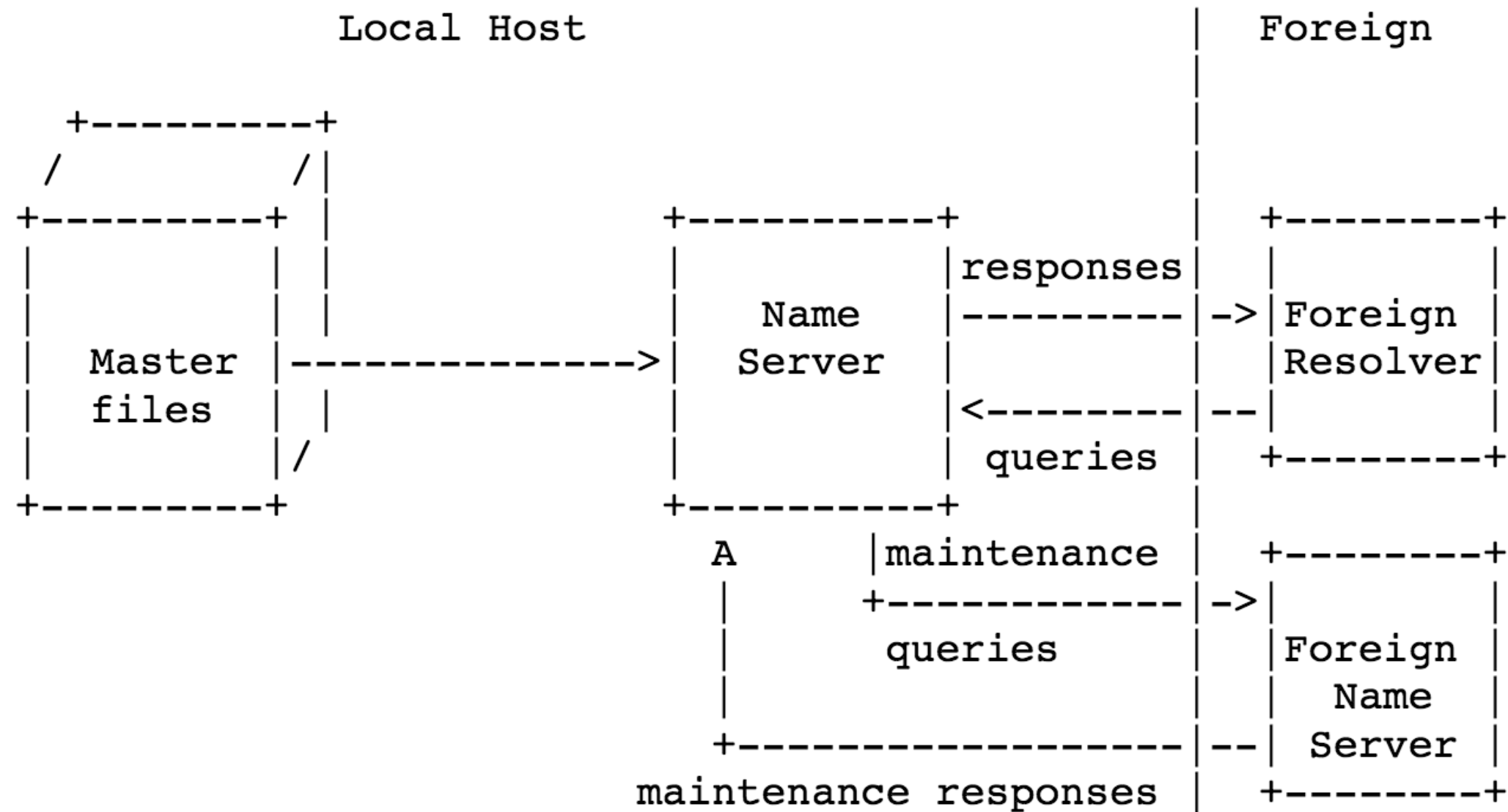
典型主机端DNS工作流程

DNS 工作流程



单独DNS服务器工作流程

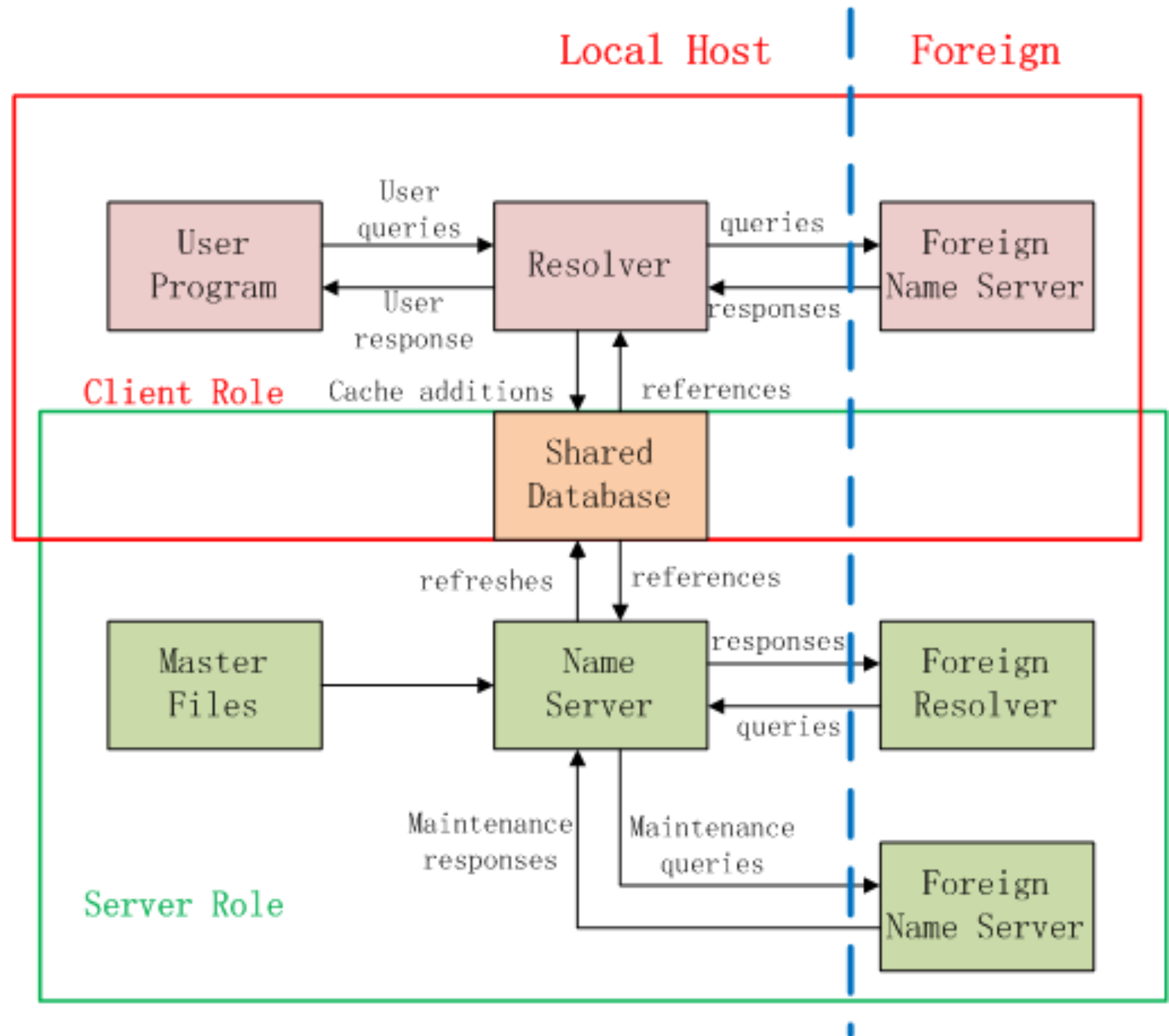
DNS 工作流程



具有辅助DNS服务器的工作流程(zone transfer)

DNS 工作流程

一个兼有客户端和服务端功能的本地主机工作方式。

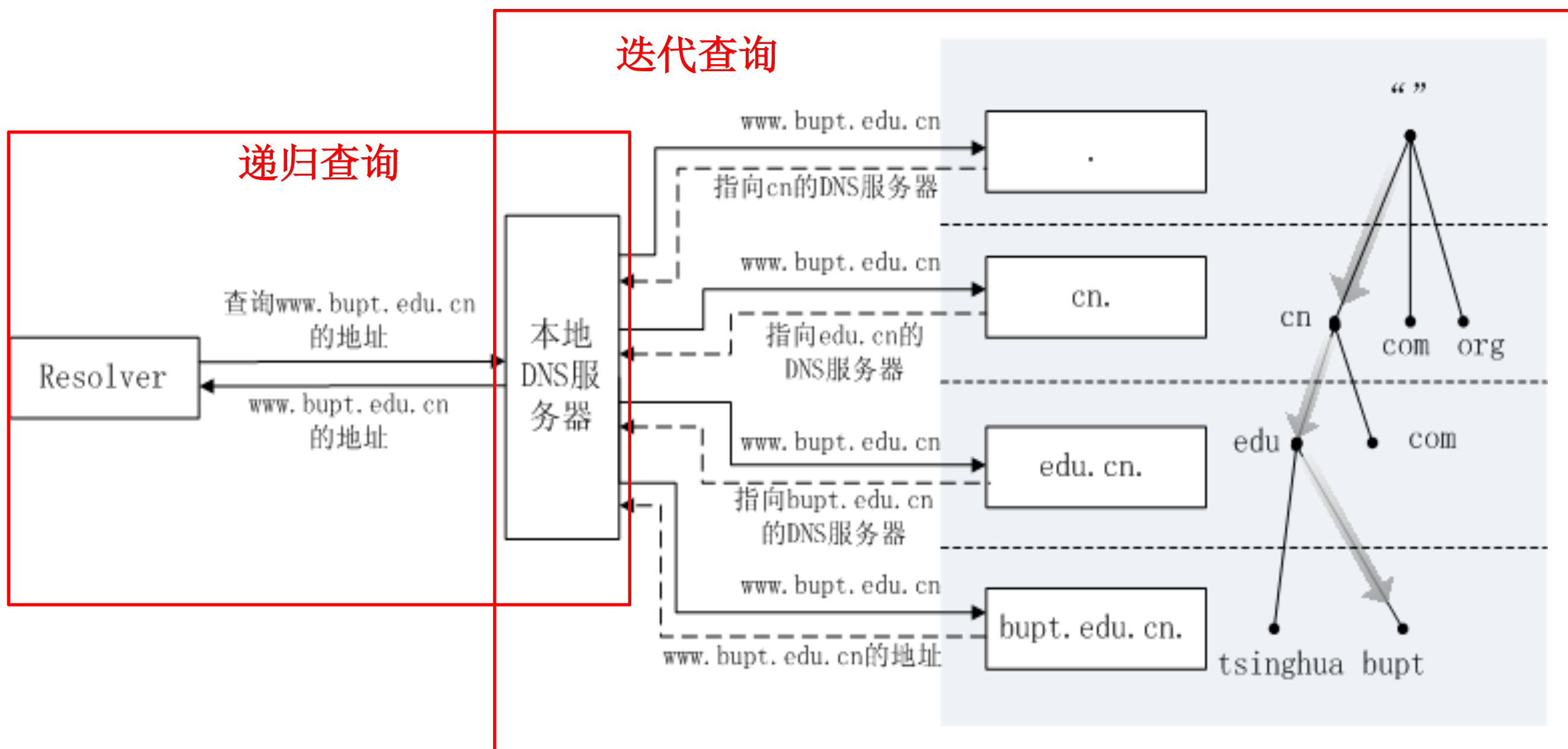


DNS工作流程

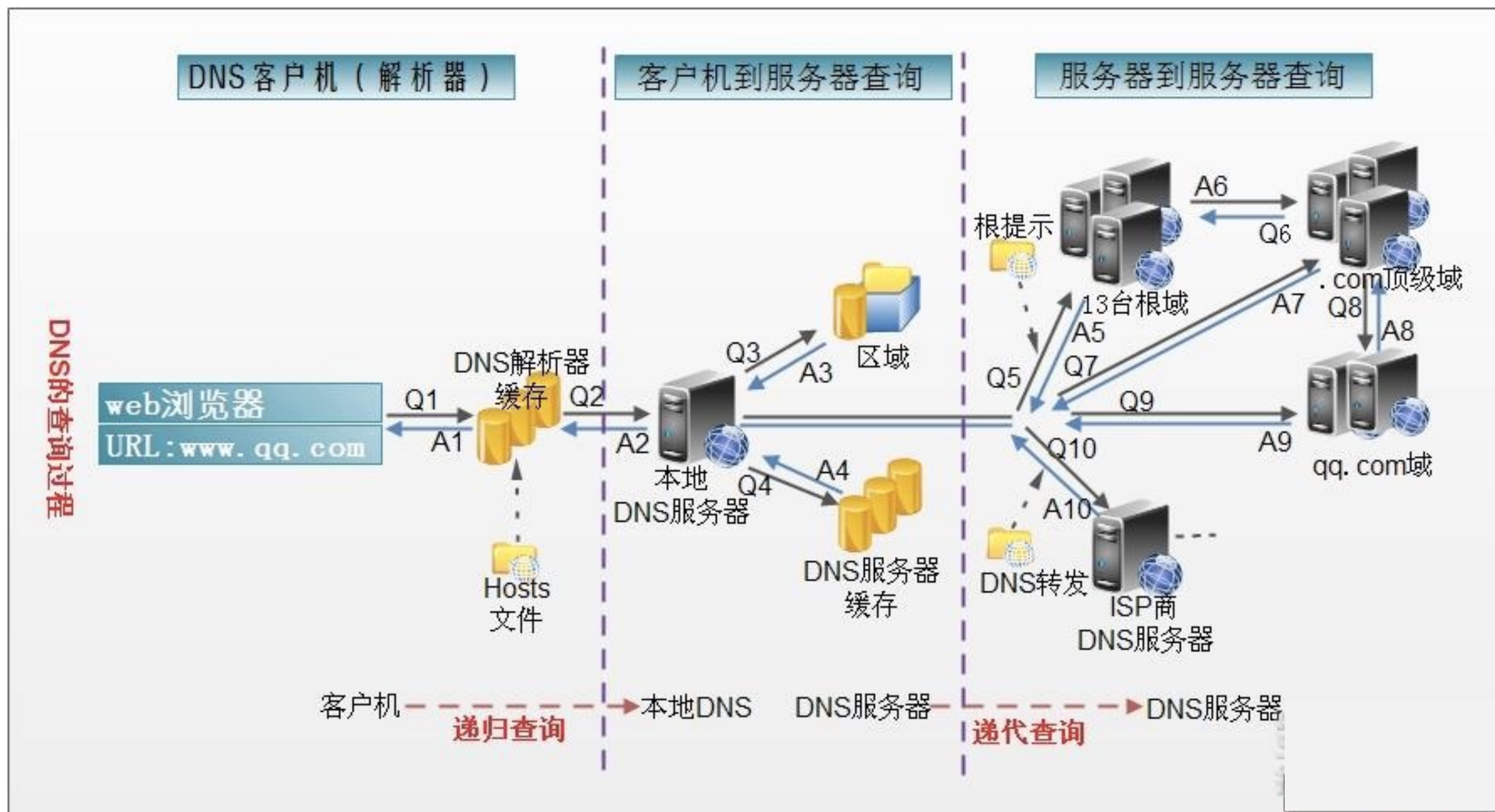
- 查询方式

- **递归查询：**一般客户机和服务器之间是递归查询，DNS服务器如果未能在本地找到相应的信息，就代替用户向其它服务器进行查询，这时它是代替用户扮演了解析器（resolver）的角色，直到最后把结果找到，也可能根本没有结果，那就返回错误，并返回给用户为止。
- **迭代查询：**一般服务器之间属于反复查询。DNS服务器返回的要么是本地存在的结果信息，要么是一个错误码，告诉查询者你要的信息这里没有，然后再返回一个可能会有查询结果的DNS服务器地址，让查询者到那里去查询。

DNS工作流程



DNS工作机制



DNS工作机制

- dig工具：

\$ dig math.stackexchange.com

```
; <<>> DiG 9.9.5-12.1-Debian <<>> math.stackexchange.com
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 6328
;; flags: qr rd ra; QUERY: 1, ANSWER: 4, AUTHORITY: 4, ADDITIONAL: 4

;; QUESTION SECTION:
;math.stackexchange.com.                IN      A

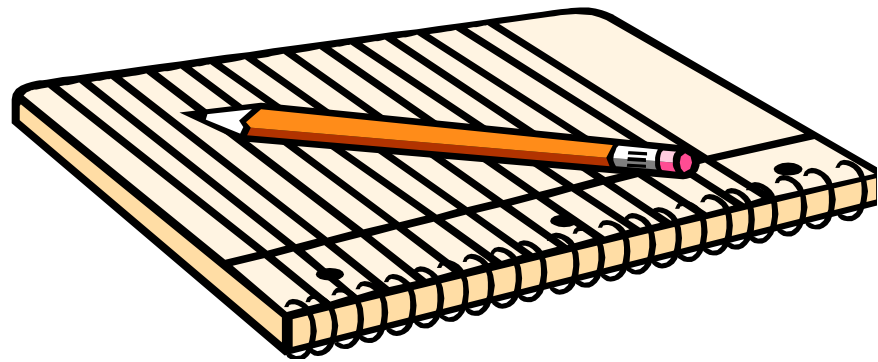
;; ANSWER SECTION:
math.stackexchange.com. 600      IN      A      151.101.65.69
math.stackexchange.com. 600      IN      A      151.101.129.69
math.stackexchange.com. 600      IN      A      151.101.193.69
math.stackexchange.com. 600      IN      A      151.101.1.69

;; AUTHORITY SECTION:
stackexchange.com.     171469   IN      NS      ns-1832.awsdns-37.co.uk.
stackexchange.com.     171469   IN      NS      ns-1029.awsdns-00.org.
stackexchange.com.     171469   IN      NS      ns-463.awsdns-57.com.
stackexchange.com.     171469   IN      NS      ns-925.awsdns-51.net.

;; ADDITIONAL SECTION:
ns-463.awsdns-57.com.  171406   IN      A      205.251.193.207
ns-925.awsdns-51.net.  171393   IN      A      205.251.195.157
ns-1029.awsdns-00.org. 171469   IN      A      205.251.196.5
ns-1832.awsdns-37.co.uk. 171393   IN      A      205.251.199.40

;; Query time: 5 msec
;; SERVER: 192.168.1.253#53(192.168.1.253)
;; WHEN: Mon Jun 13 22:12:46 CST 2016
;; MSG SIZE rcvd: 305
```


DNS安全威胁及防范



- DNS概述

- DNS工作流程

- DNS协议

- DNS安全威胁

- DNS安全防范

DNS协议

- DNS协议工作在哪一层？

应用层

DNS协议

- DNS基于TCP or UDP ?
- DNS既可以使用TCP，又可以使用UDP，端口为53.
 - DNS主从服务器之间区传送传输时使用TCP协议
 - 客户端与DNS服务器之间传输时用的是UDP协议

DNS协议



DNS协议报文格式

DNS协议

头部：

- **会话标识（2字节）**：是DNS报文的ID标识，对于请求报文和其对应的应答报文，这个字段是相同的，通过它可以区分DNS应答报文是哪个请求的响应
- **标志位**：

Flags	QR	opcode	AA	TC	RD	RA	(zero)	rcode
	1	4	1	1	1	1	3	4

- **数量字段**：

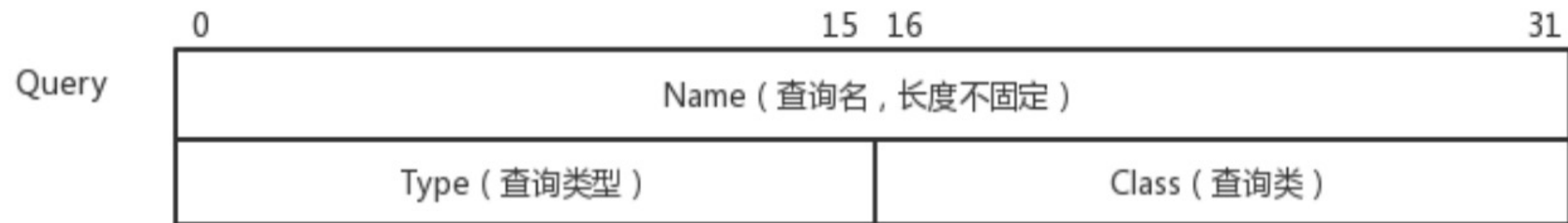
数量字段（总共8字节）：Questions、Answer RRs、Authority RRs、Additional RRs 各自表示后面的四个区域的数目。Questions表示查询问题区域节的数量，Answer RRs表示回答区域的数量，Authority RRs表示授权区域的数量，Additional RRs表示附加区域的数量

DNS协议

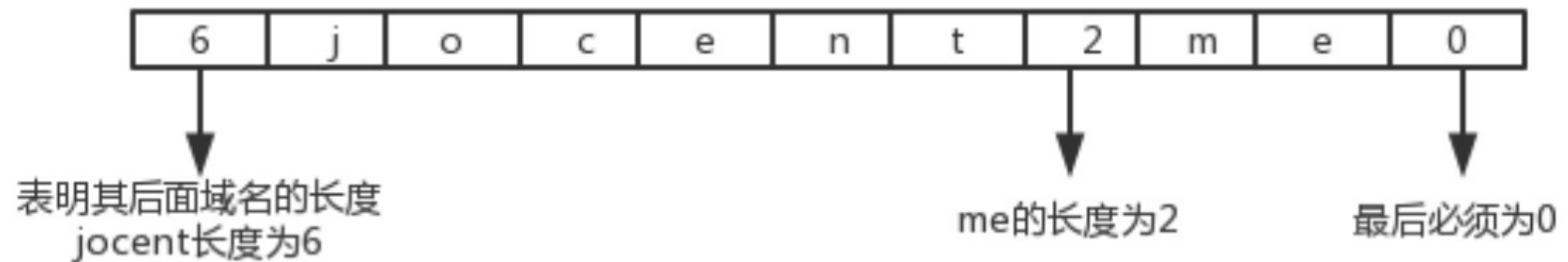
- Flags
 - QR– 识别查询和答复消息的1位字段： 0 查询； 1 应答；
 - Opcode – 描述消息类型的4位字段：
 - 0 标准查询（由名字到地址）；
 - 1 反向查询；
 - 2 服务状态请求；
 - AA – 授权回答：1位字段。当设置为1时，识别由命令名字服务器作出的答复
 - TC – 可切断。1位字段。当设置为1，表明消息已被切断。
 - RD – 1位字段。由名字服务器设置为1请求递归服务。
 - RA – 1位字段。由名字服务器设置表示递归服务的可用性。
 - Z – 3位字段。备用，设置为0。
 - Rcode – 响应代码，由名字服务器设置的4位字段用以识别查询状态。表示返回码，0表示没有差错，3表示名字差错，2表示服务器错误（Server Failure）

DNS协议

- 正文
 - Queries 区域



查询名：长度不固定，且不使用填充字节，一般该字段表示的就是需要查询的域名（如果是反向查询，则为IP，反向查询即由IP地址反查域名）



DNS协议

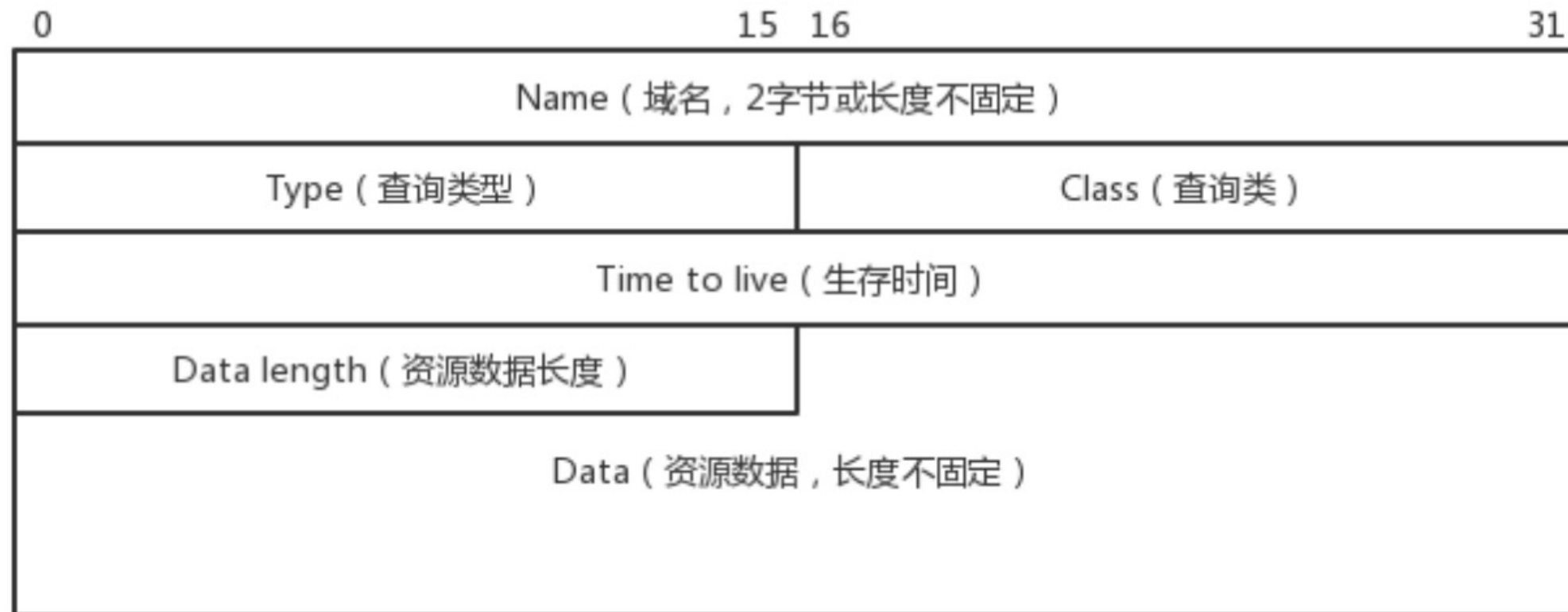
查询类型

类型	助记符	说明
1	A	由域名获得IPv4地址
2	NS	查询域名服务器
5	CNAME	查询规范名称
6	SOA	开始授权
11	WKS	熟知服务
12	PTR	把IP地址转换成域名
13	HINFO	主机信息
15	MX	邮件交换
28	AAAA	由域名获得IPv6地址
252	AXFR	传送整个区的请求
255	ANY	对所有记录的请求

查询类：通常为1，表明是Internet数据

DNS协议

- 资源记录(RR)区域 (包括回答区域, 授权区域和附加区域)



资源记录格式

DNS协议

域名（2字节或不定长）：

格式和Queries区域的查询名字字段是一样的。。

查询类型：

表明资源记录的类型，同Queries。

查询类：

对于Internet信息，总是1。

DNS协议

生存时间（TTL）：以秒为单位，表示的是资源记录的生命周期，一般用于当地址解析程序取出资源记录后决定保存及使用缓存数据的时间，它同时也可以表明该资源记录的稳定程度，极为稳定的信息会被分配一个很大的值（比如86400，这是一天的秒数）。

资源数据：该字段是一个可变长字段，表示按照查询段的要求返回的相关资源记录的数据。可以是Address（表明查询报文想要的回应是一个IP地址）或者CNAME（表明查询报文想要的回应是一个规范主机名）等。

DNS协议

No. ↓	Time	Source	Destination	Protocol	Info
14	6.919898	172.16.0.113	172.16.0.4	DNS	Standard query A hhz.242.net
15	6.920977	172.16.0.4	172.16.0.113	DNS	Standard query response A 222.128.5.182

+	Frame 15 (87 bytes on wire, 87 bytes captured)
+	Ethernet II, Src: 172.16.0.4 (00:0c:29:f8:9e:14), Dst: 172.16.0.113 (00:19:d1:4f:df:4e)
+	Internet Protocol, Src: 172.16.0.4 (172.16.0.4), Dst: 172.16.0.113 (172.16.0.113)
+	User Datagram Protocol, Src Port: domain (53), Dst Port: 1063 (1063)
[-]	Domain Name System (response)
	Transaction ID: 0x0008
[-]	Flags: 0x8180 (Standard query response, No error)
	1... .. = Response: Message is a response
	.000 0... .. = Opcode: standard query (0)
	0.. = Authoritative: Server is not an authority for domain
	0. = Truncated: Message is not truncated
	1 = Recursion desired: Do query recursively
	 1... .. = Recursion available: Server can do recursive queries
	0.. = Z: reserved (0)
	0. = Answer authenticated: Answer/authority portion was not authenticated by the server
	 0000 = Reply code: No error (0)
	Questions: 1
	Answer RRs: 1
	Authority RRs: 0
	Additional RRs: 0
[-]	Queries
	[-] hhz.242.net: type A, class IN
	Name: hhz.242.net
	Type: A (Host address)
	Class: IN (0x0001)
[-]	Answers
	[-] hhz.242.net: type A, class IN, addr 222.128.5.182
	Name: hhz.242.net
	Type: A (Host address)
	Class: IN (0x0001)
	Time to live: 12 minutes, 17 seconds
	Data length: 4
	Addr: 222.128.5.182

DNS安全威胁及防范

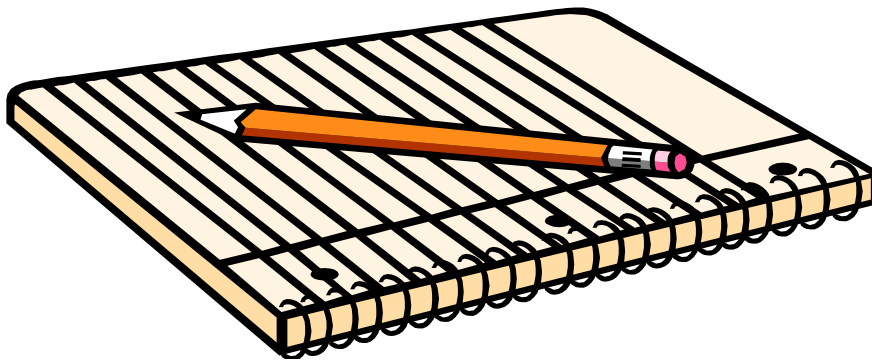
- DNS概述

- DNS工作流程

- DNS协议

- DNS安全威胁

- DNS安全防范



DNS安全威胁

- 安全缺陷

- 单点故障
- 软件实现漏洞
 - 缓冲区溢出
 - 拒绝服务

- 恶意攻击

- 欺骗（ DNS spoofing ）
- 缓存中毒（ cache posioning ）
- 缓冲区溢出漏洞攻击
- 拒绝服务攻击
- 信息泄露

DNS安全威胁

- DNS应答包被客户端接受需要满足以下五个条件
 - 1、 应答包question域和请求包question域的域名信息一致。
 - 2、 应答包的Transaction ID和请求包中的Transaction ID一致。
 - 3、 应答包的源IP地址与请求包的目的IP地址一致。
 - 4、 应答包的目的IP地址和端口与请求包的源IP地址和端口一致。
 - 5、 第一个到达的符合以上四个条件的应答包。
- 从以上五个条件可以看出，最初设计DNS时没有考虑它的安全问题，这导致DNS协议存在很多漏洞，这使得DNS很容易受到攻击。

DNS安全威胁

- DNS的安全漏洞主要体现在以下三个方面。
 - (1) DNS报文只使用**序列号**来进行有效性鉴别，序列号由客户程序设置并由服务器返回结果，客户程序通过它来确定响应与查询是否匹配，这就引入了序列号攻击的危险。

DNS安全威胁

- DNS的安全漏洞主要体现在以下三个方面。
 - (2) 从协议定义上来看，在DNS应答报文中可以**附加信息**，该信息可以和所请求的信息没有直接关系，这样，攻击者就可以在应答中随意添加某些信息，如：指示某域的权威域名服务器的域名及IP，导致在被影响的域名服务器上查询该域的请求都会被转向攻击者所指定的域名服务器上去，从而对网络的完整性构成威胁。

DNS安全威胁

- DNS的安全漏洞主要体现在以下三个方面。
 - (3) DNS的**缓存机制**，当一个客户端/DNS服务器，收到有关域名和IP的映射信息时，它会将该信息存放在缓存中，当再次遇到对此域名的查询请求时就直接使用缓存中的结果而无需重新查询。
可以通过ipconfig /displaydns命令查看本地DNS缓存信息。

DNS安全威胁

- 1992 年，Danzig 等人从类 RPC 流 (RPC-like Traffic) 的角度对 DNS 的一个根域名服务器 (Root Server) 进行了测量，发现其在缓存机制、超时重传算法和替代服务器选择算法方面存在 **7 类实现错误**。研究表明由于这些错误的大量存在导致 DNS 占用的广域网带宽**超出其所需带宽 20 倍以上**。

DNS安全威胁

- 2001 年，Brownlee 等人对 F 根服务器和通用顶级域名服务器（gTLD）的安全性进行了全方位的测量，结果显示尽管历经了 10 年，Danzig 在 1992 年发现的 DNS 脆弱性依然大量存在，伪造的 A 类型查询、重复查询、无效 TLD 查询以及利用根服务器发起的 DoS 攻击不仅极大影响了全球 DNS 的性能，也严重威胁着整个互联网的安全性。

DNS安全威胁

- 操作脆弱性

- 域名配置攻击

- 有意攻击、无意攻击

- 域名注册攻击

- 域名注册管理公司的注册域名记录

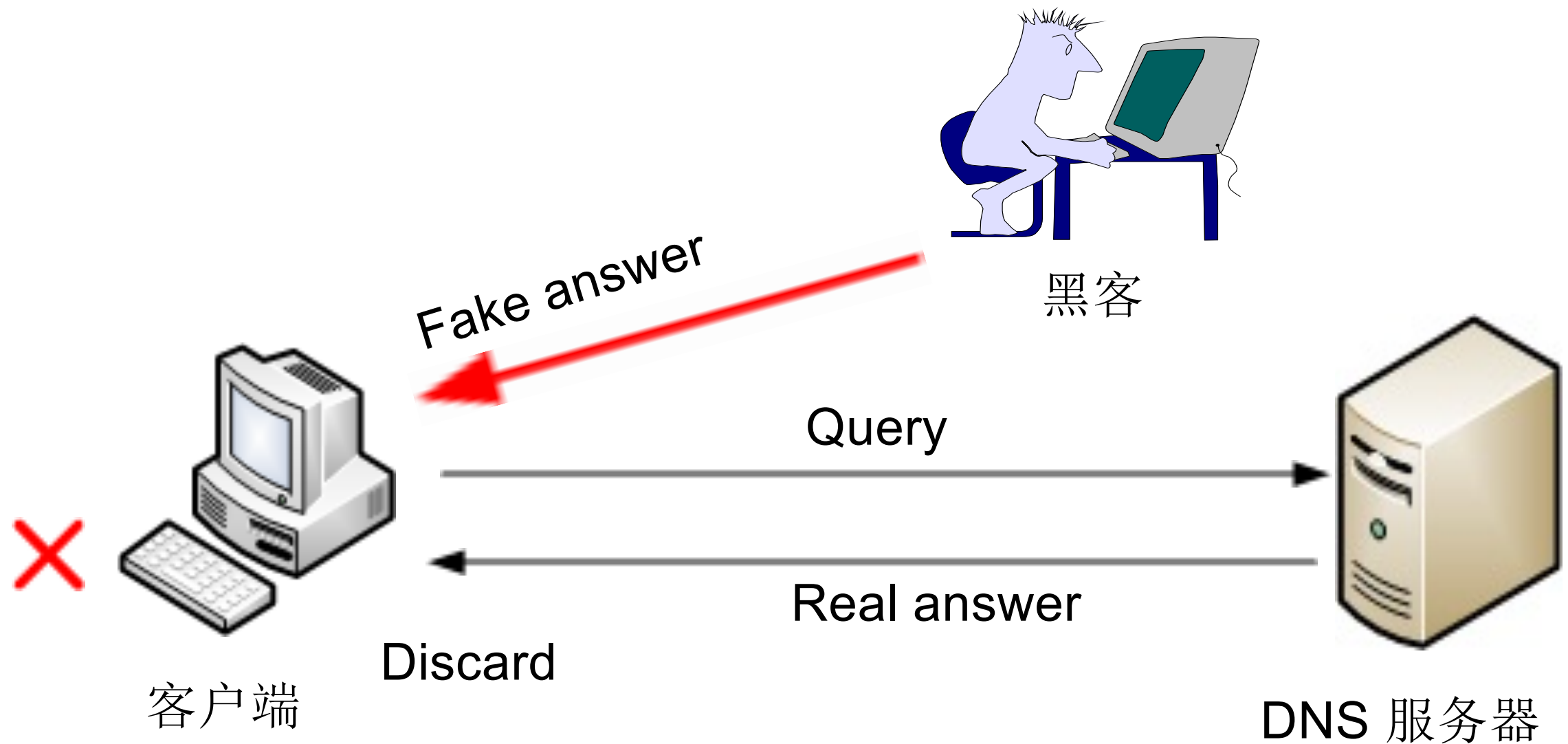
- 域名劫持 、 类似域名注册

- 信息泄漏

- 区传送过程中，辅助DNS服务器从主DNS服务器同步信息，泄露内部网络拓扑、主机名和操作系统的数据。

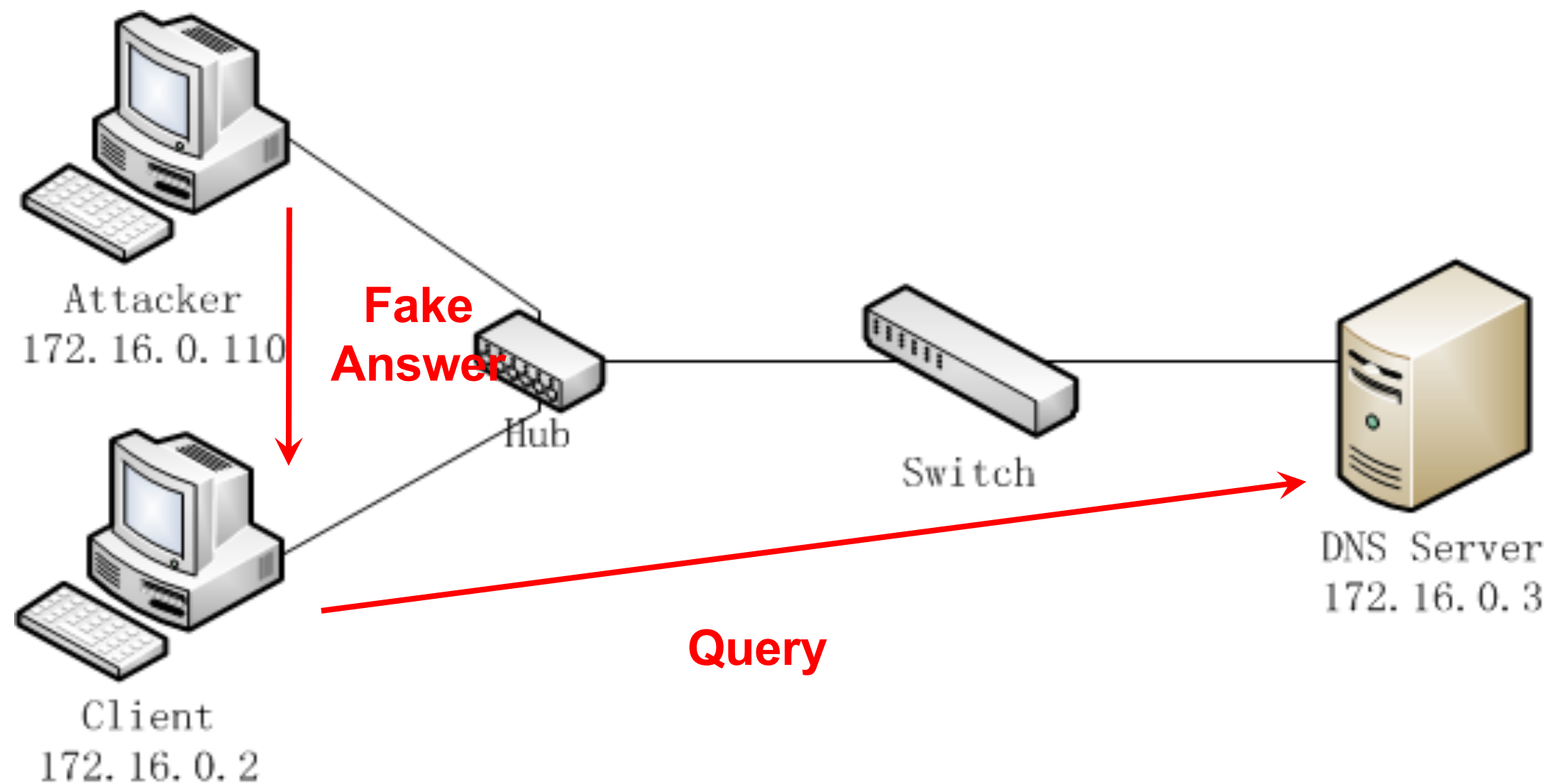
DNS安全威胁

- DNS欺骗攻击流程



DNS安全威胁

- 测试环境:攻击者可以监听到Client与Server之间的通信。



DNS安全威胁

- 如下图所示第二个数据包是攻击者（172.16.0.110）伪装成（172.16.0.3）返回的虚假应答包，由于它是第一个到达的符合条件的数据包，所以会被（172.16.0.2）接受。当（172.16.0.2）通过域名hhz.242.net去访问主机时，会被错误的引导到（172.16.0.110）。
- 同样如果172.16.0.2访问银行或网上交易的网站时，攻击者也可以将其引导到错误的地址，通过虚假网页，进行一些不法行为，如盗取银行帐号及密码等信息。

No. ↓	Time	Source	Destination	Protocol	Info
2	0.000300	172.16.0.2	172.16.0.3	DNS	Standard query A hhz.242.net
3	0.022569	172.16.0.3	172.16.0.2	DNS	Standard query response A 172.16.0.110
4	0.024043	172.16.0.3	172.16.0.2	DNS	Standard query response A 172.16.0.113

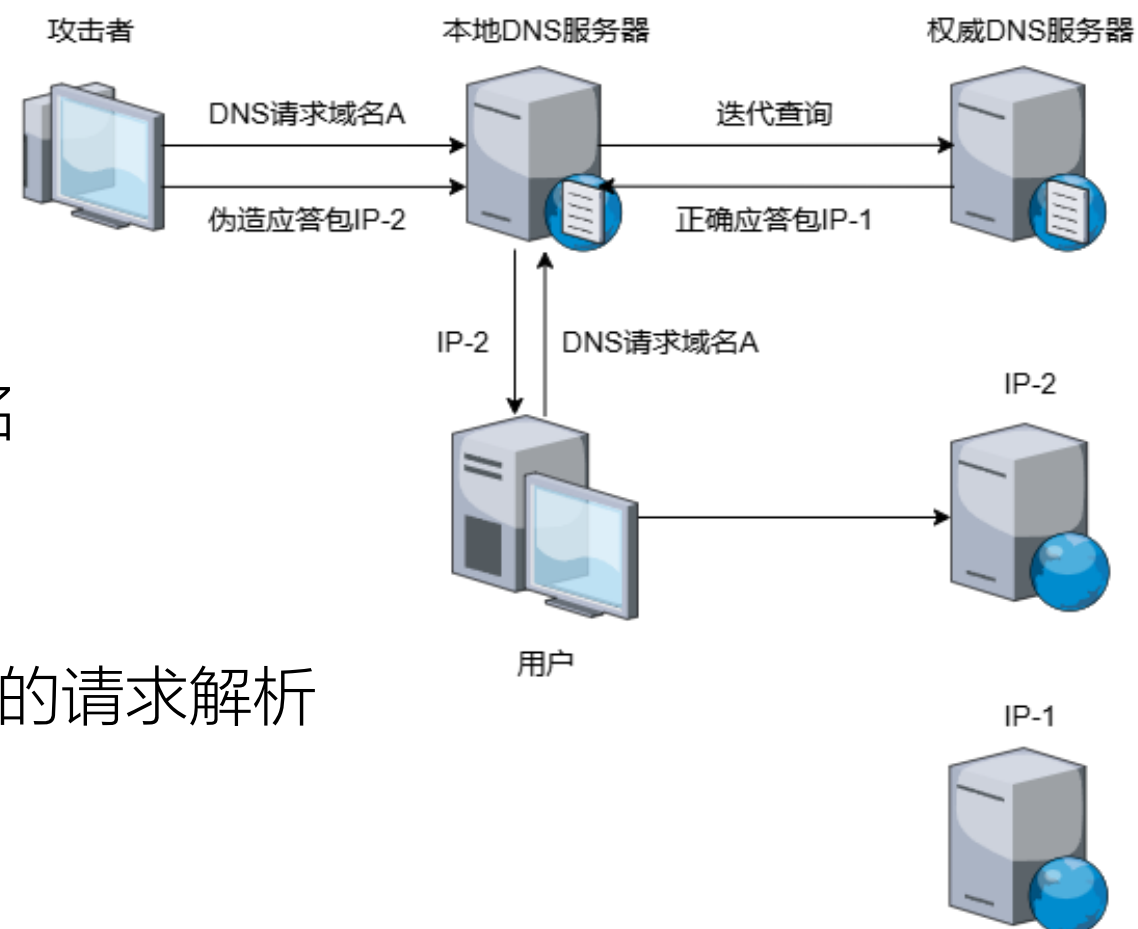
+	Frame 3 (144 bytes on wire, 144 bytes captured)
+	Ethernet II, Src: vmware_f8:9e:14 (00:0c:29:f8:9e:14), Dst: LanTech_6f:32:35 (00:c0:26:6f:32:35)
+	Internet Protocol, Src: 172.16.0.3 (172.16.0.3), Dst: 172.16.0.2 (172.16.0.2)
+	User Datagram Protocol, Src Port: domain (53), Dst Port: 1031 (1031)
+	Domain Name System (response)

DNS安全威胁

- DNS缓存投毒：主要依赖于缓存机制
- 原理：利用DNS的简单信任机制与缓存机制，向DNS服务器发送伪造应答包，实现DNS缓存的投毒
- 简单信任机制：域名解析的过程中，使用明文UDP包进行交互，客户端发送DNS请求后，对最先收到的应答包仅进行源IP、目的IP、ID和question域的确认，无其他合法性检查，若匹配则接收并丢弃后续应答包
- 缓存机制：接收合法（不一定正确）应答包后进行解析，解析结果会进行缓存，具体时间取决于授权DNS的TTL决定（非浏览器缓存）

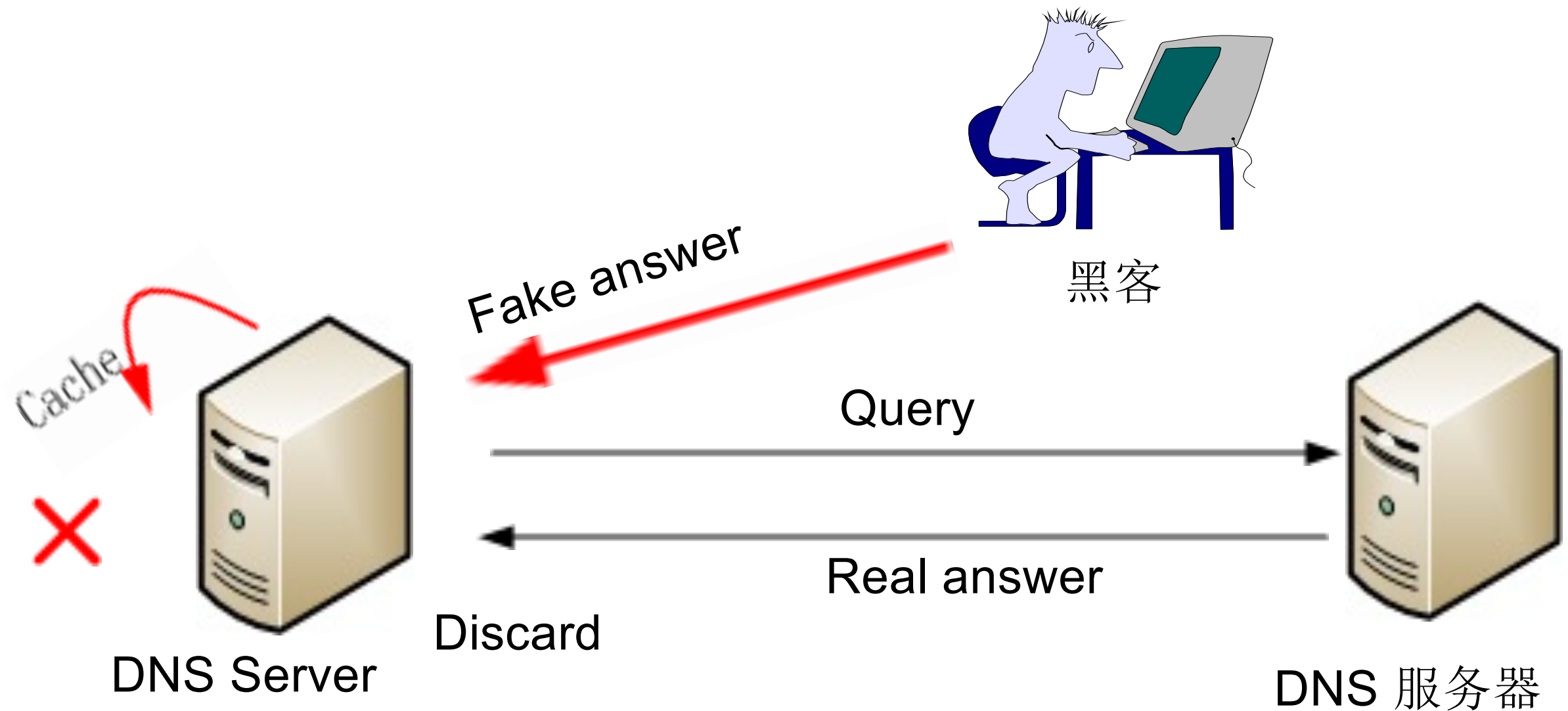
DNS安全威胁

- DNS缓存投毒：主要发生在本地DNS服务器向权威DNS服务器发送查询时
- 攻击者获取DNS请求报文中的IP、端口和ID，伪造响应包
- 攻击者用大量的伪造包尝试淹没正常响应，若成功攻击，则本地DNS服务器将为该域名缓存错误的IP
- 此本地DNS服务器会将该域内所有对域名A的请求解析为错误IP
- 若成功伪造并使其缓存了某权威DNS服务器响应包，可以将DNS查询转发到攻击者控制的DNS服务器中



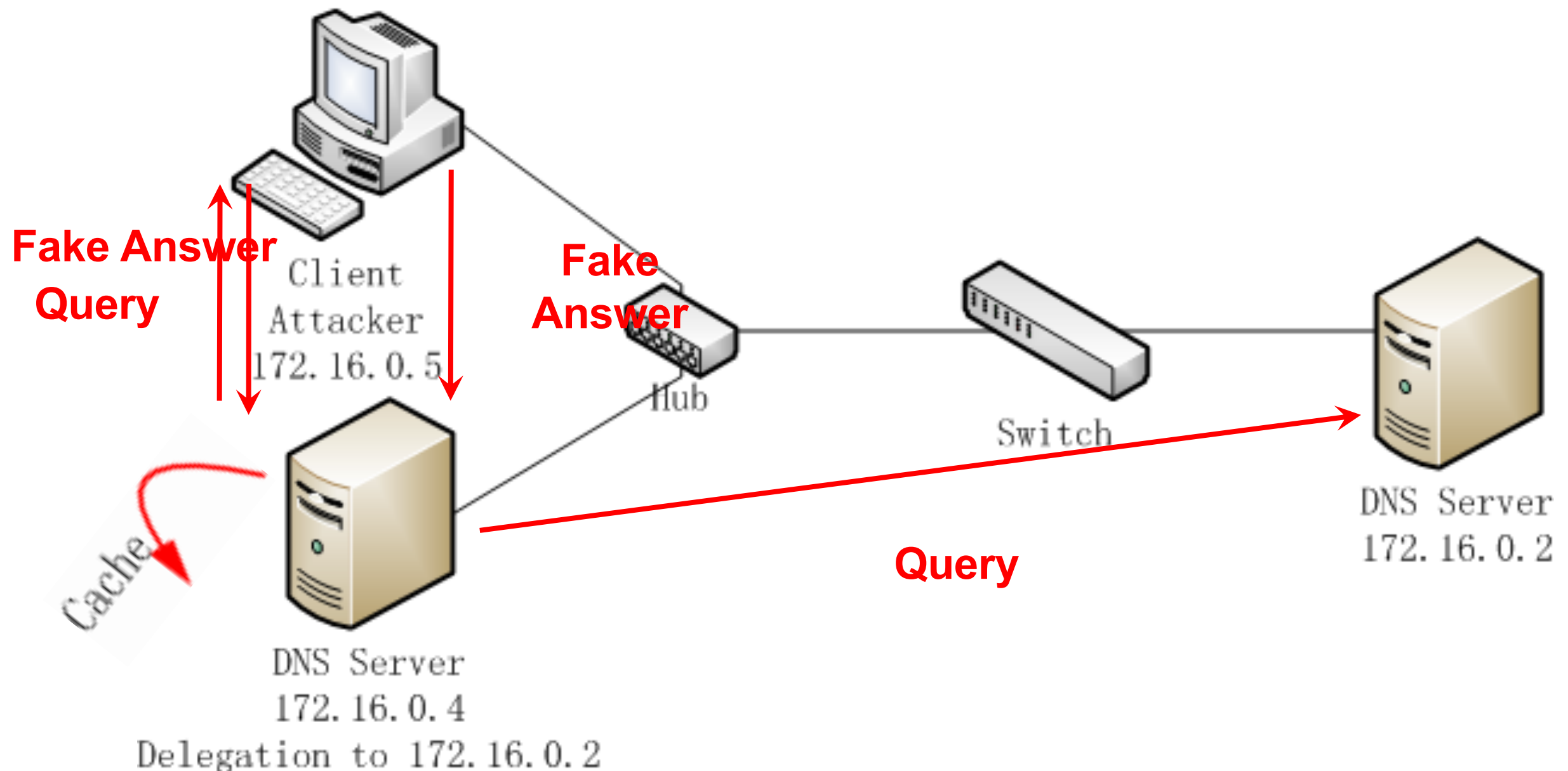
DNS安全威胁

- DNS下毒攻击流程



DNS安全威胁

- 测试环境：攻击者可以能够监听到DNS服务器之间的通信。



DNS安全威胁

- 下图中第三个数据包是攻击者（172.16.0.5）伪装成服务器（172.16.0.2）发送的应答包，这样就可以把虚假信息：1.242.com对应的IP地址为222.128.5.182放入服务器（172.16.0.4）的缓存中。

No. ↓	Time	Source	Destination	Protocol	Info
64	35.880263	172.16.0.5	172.16.0.4	DNS	standard query A 1.242.com
67	35.882126	172.16.0.4	172.16.0.2	DNS	standard query A 1.242.com
68	35.905786	172.16.0.2	172.16.0.4	DNS	standard query response A 222.128.5.182
69	35.907278	172.16.0.4	172.16.0.5	DNS	standard query response A 222.128.5.182

```
+ Frame 69 (103 bytes on wire, 103 bytes captured)
+ Ethernet II, Src: 172.16.0.4 (00:0c:29:2c:0b:bb), Dst: 172.16.0.5 (00:0c:29:02:53:f8)
+ Internet Protocol, Src: 172.16.0.4 (172.16.0.4), Dst: 172.16.0.5 (172.16.0.5)
+ User Datagram Protocol, Src Port: domain (53), Dst Port: 35047 (35047)
- Domain Name System (response)
  Transaction ID: 0x3cc8
  + Flags: 0x8180 (standard query response, No error)
  Questions: 1
  Answer RRs: 1
  Authority RRs: 1
  Additional RRs: 0
  + Queries
  - Answers
    - 1.242.com: type A, class IN, addr 222.128.5.182
      Name: 1.242.com
      Type: A (Host address)
      Class: IN (0x0001)
      Time to live: 15 minutes
      Data length: 4
      Addr: 222.128.5.182
```

DNS安全威胁

- 下毒结果验证：172.16.0.5再次向DNS服务器172.16.0.4查询1.242.com的信息，可以看到DNS服务器没有向172.16.0.2查询，而是直接给出了应答，这说明它的缓存中存在1.242.com的信息，通过抓包分析，下毒攻击是成功的。此类攻击时一般会将TTL值设成较长的时间。

No.	Time	Source	Destination	Protocol	Info
1	0.000000	172.16.0.5	172.16.0.4	DNS	Standard query A 1.242.com
2	0.000548	172.16.0.4	172.16.0.5	DNS	Standard query response A 222.128.5.182
5	18.633558	172.16.0.5	172.16.0.4	DNS	Standard query A 1.242.com
6	18.634624	172.16.0.4	172.16.0.5	DNS	Standard query response A 222.128.5.182

+	User Datagram Protocol, Src Port: domain (53), Dst Port: 35134 (35134)
-	Domain Name System (response) - Transaction ID: 0xdba0 - Flags: 0x8180 (Standard query response, No error) - Questions: 1 - Answer RRs: 1 - Authority RRs: 1 - Additional RRs: 0 - Queries - Answers 1.242.com: type A, class IN, addr 222.128.5.182 - Name: 1.242.com - Type: A (Host address) - Class: IN (0x0001) - Time to live: 1 minute, 51 seconds <u>Data length: 4</u> - Addr: 222.128.5.182

DNS安全威胁

- 缓冲区溢出攻击
 - **BIND 软件的许多版本存在缓冲区溢出漏洞**，当攻击者获取了管理员的权限时，就可以入侵BIND所在的主机，并可执行任意指令，这种攻击危害比较严重，攻击者不仅可以获得DNS服务器所在域的数据信息，还可以任意修改该域的数据。针对这种攻击需要及时发现BIND的版本漏洞，并进行升级。
 - 黑客利用DNS服务器软件存在的漏洞实施攻击，比如特定的输入没有进行严格检查，那么就有可能被攻击者利用，攻击者构造特定的畸形数据包来对DNS服务器进行缓冲区溢出攻击。

DNS安全威胁

- 缓冲区溢出攻击的危害主要包括：
 - 1、更改MX记录，造成邮件被截获、修改或删除。
 - 2、更改A记录，将www服务器的域名指向黑客具有的同样www内容的主机，诱使访问者登陆，获取访问者的密码等相关信息
 - 3、利用这台主机作为攻击其他机器的跳板

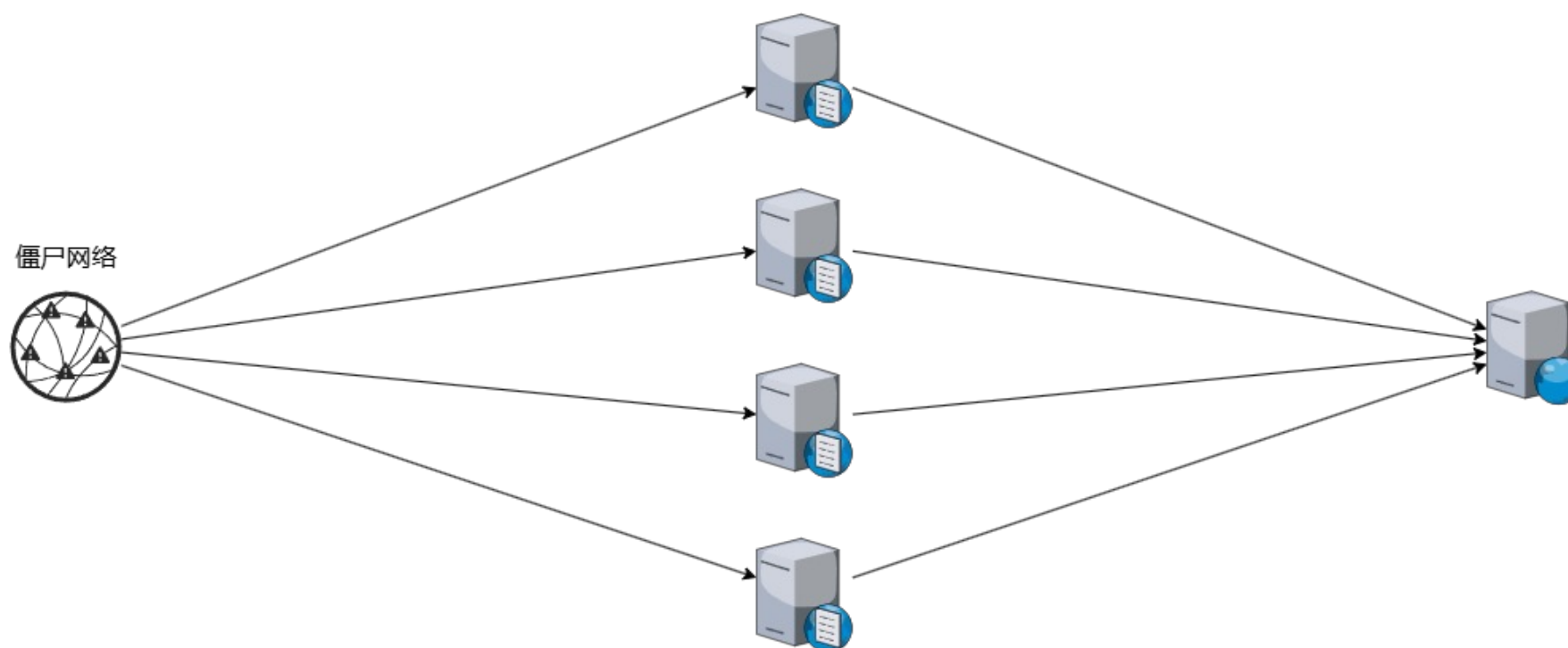
DNS安全威胁

- 拒绝服务攻击

- 黑客主要利用一些DNS软件的漏洞，如BIND 9版本（版本9.2.0以前的9系列）。如果向运行BIND的设备发送特定的DNS数据包请求，BIND就会自动关闭。攻击者只能是BIND停止提供域名解析服务而不能在服务器上执行任何口令。
- 造成的危害是：域名无法解析为IP地址，用户无法访问互联网

DNS放大攻击

- 一种DDoS攻击
- 原理：攻击者以受害者IP作为源地址，向开放DNS服务器发送大量DNS请求，使受害者服务器或网络造成堵塞，使其无法正常使用
- 通过使用僵尸网络，既可以有效规避检测，又可以产生大量流量



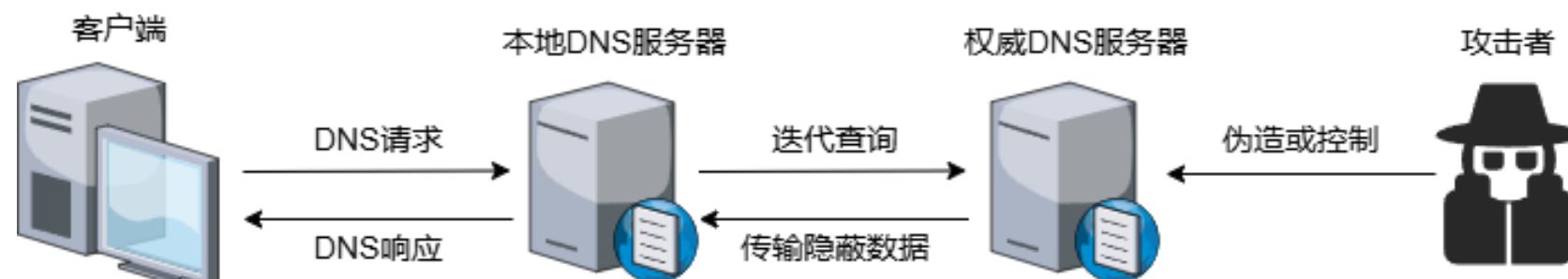
DNS安全威胁

- 信息泄露

- BIND软件默认设置是允许主机间进行区传送（ZoneTransfer）。区传送的主要目的是用于主DNS和辅DNS之间的数据同步，使辅DNS可以从主DNS获得新的数据信息。
- 一旦启用区传送，而不做任何限制，很可能造成信息泄露，黑客可以获得整个授权域内的所有主机信息，判断主机功能及安全性，从中发现目标进行攻击。
- 一旦这些信息泄露，攻击者就可以根据它推测出主域名服务器的网络结构，为进一步攻击提供参考依据。

利用DNS的攻击——DNS隧道

- 原理：利用DNS协议的定义，可以在DNS查询和响应包中传输通信数据
- 根据RFC 1034，DNS响应包中的传输数据未做限制，如A记录应返回IP，但实际可返回其它字符串
- 客户端（恶意软件）可以将传输数据编码到域名前缀，如YnVwdA==.css.com，并分块进行DNS请求，请求类型可以为TXT、CNAME、A等
- 攻击者需注册一个域名，并伪造或控制一个相应的权威DNS服务器，将通信数据写入权威服务器，通过DNS响应回传到客户端，实现隐蔽通信

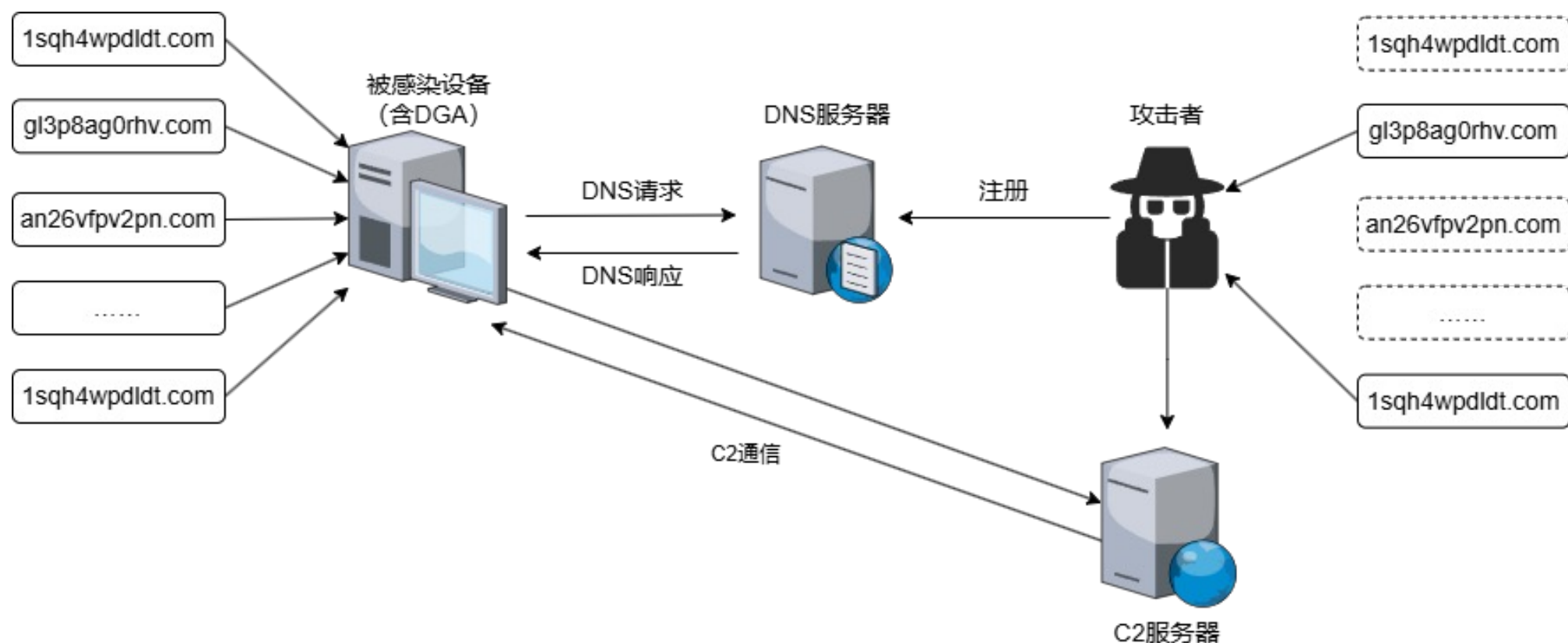


利用DNS的攻击——DGA

- 域名生成算法 (Domain Generation Algorithm, DGA) : 一种使用伪随机算法, 以特定种子作为输入, 生成大量域名的技术
- 种子需保证恶意软件与攻击者可以同时或提前获取, 如硬编码、时间信息、外汇汇率等
- 伪随机算法类型不限, 包括但不限于基于算术运算、位运算, 如LCG; 基于加密算法、哈希, 如RC4; 基于字典等
- DGA可以结合DNS隧道
- 真实案例: Conficker、Zloader、Necurs

利用DNS的攻击——DGA

- 可以绕过传统的基于黑名单的过滤方法
- 原理：攻击者与恶意软件使用相同的种子运行相同的DGA算法，二者得到相同的域名列表；恶意软件会对生成的所有域名请求解析并尝试建立连接；攻击者仅需选取其中少量的域名进行注册，即可实现与恶意软件的交互



利用DNS的攻击—DGA(Mirai)

奇安信X实验室(XLab)于2024年3月捕获了一个使用DGA的Mirai家族变种

- DGA种子：基于时间生成
- 大多数基于时间的DGA通过获取系统时间生成种子，但该变种使用NTP服务进行获取
- 在程序中硬编码了多个公共NTP的IP地址，获取NTP返回数据中的Reference时间戳之后，将其与604800整除，若获取失败，种子赋值为9999

24 6.775761	10.0.2.15	129.6.15.28	NTP	90 NTP Version 3, client
32 16.767864	10.0.2.15	129.6.15.28	NTP	90 NTP Version 3, client
48 26.622392	10.0.2.15	129.6.15.28	NTP	90 NTP Version 3, client
73 47.080976	10.0.2.15	129.6.15.28	NTP	90 NTP Version 3, client
25 7.022809	129.6.15.28	10.0.2.15	NTP	90 NTP Version 3, server
33 17.000269	129.6.15.28	10.0.2.15	NTP	90 NTP Version 3, server
49 26.859966	129.6.15.28	10.0.2.15	NTP	90 NTP Version 3, server
74 47.313621	129.6.15.28	10.0.2.15	NTP	90 NTP Version 3, server

```
> Flags: 0x1c, Leap Indicator: no warning, Version number: NTP Vers: ^
[Request In: 24]
[Delta Time: 0.247048000 seconds]
Peer Clock Stratum: primary reference (1)
Peer Polling Interval: 13 (8192 seconds)
Peer Clock Precision: 0.000000 seconds
Root Delay: 0.000244 seconds
Root Dispersion: 0.000488 seconds
Reference ID: NIST telephone modem
Reference Timestamp: Mar  7, 2024 02:01:36.000000000 UTC
Origin Timestamp: NULL
Receive Timestamp: Mar  7, 2024 02:02:27.569599950 UTC
Transmit Timestamp: Mar  7, 2024 02:02:27.569601424 UTC
```

0000	52 54 00 12 34 56 52 55	0a 00 02 02 08 00 45 00
0010	00 4c 00 12 00 00 40 11	de 5e 81 06 0f 1c 0a 00
0020	02 0f 00 7b 98 31 00 38	8f 1a 1c 01 0d e3 00 00
0030	00 10 00 00 00 20 4e 49	53 54 e9 93 9e 80 00 00
0040	00 00 00 00 00 00 00 00	00 00 e9 93 9e b3 91 d1
0050	4d 69 e9 93 9e b3 91 d1	66 24

利用DNS的攻击—DGA(Mirai)

- 伪随机算法：生成的域名由两部分组成
- 第一部分：时间种子经过MD5编码和chacha20算法加密后，选取最终的16进制字符串的10个指定字符
- 第二部分：从字符串表解密获得的顶级域名、DDNS域名
- 需要注意，该算法中chacha20的密钥为16字节
- 在最后一次MD5，使用的数据长度被固定为64，因此需要补0

```
1 import datetime
2 import hashlib
3 import string
4
5 from chacha20 import chacha20_cipher
6
7 dt = datetime.datetime.timestamp(datetime.datetime.utcnow())
8 timeseed = str(int(dt) // 604800)
9 tlds = [".dontargetme.nl", ".ru", ".nl", ".xyz", ".duckdns.org", ".chickenkiller.com", ".accesscam.org", ".casacam.net",
10         ".ddnsfree.com", ".mooo.com", ".strangled.net", ".ignorelist.com", ".geek", ".oss", ".webserversalosinginxo.ru",
11         ".session.oss", ".session.geek"]
12 sld = bytearray()
13 for i, c in enumerate(timeseed):
14     if not c.isdigit():
15         sld.append((5 * ord(c) - 477) % 26 + ord('a'))
16     else:
17         sld.append(ord(c))
18 md5_hex = bytearray(hashlib.md5(sld).hexdigest().encode())
19 xx20data = bytearray()
20 sort_index = [31, 2, 5, 4, 0, 18, 26, 21, 29, 4, 2, 6]
21 for index in sort_index:
22     xx20data.append(md5_hex[index])
23
24 xx20key = bytearray.fromhex("764D1ABCF84ED5673B85B46EFA044D2E")
25 xx20nonce = bytearray.fromhex("1F786E3950864D1EAA82042")
26 md5data = chacha20_cipher(xx20key, xx20nonce, xx20data, 12)
27 m5 = bytearray(hashlib.md5(md5 + b"\x00" * (64 - len(res))).hexdigest().encode())
28 sort_index1 = [11, 12, 15, 14, 10, 18, 16, 1, 9, 14]
29 sld = bytearray()
30 for index in sort_index1:
31     sld.append(m5[index])
32 for tld in tlds:
33     print(sld.decode() + tld)
34
```


利用DNS的攻击—DGA(Mirai)

- 获取C2地址：AES解密
- 该程序中硬编码了多个公共DNS服务器的地址，用于获取上述生成域名的TXT记录
- 对获取的十六进制字符串进行AES-256-CBC解密，即可获得最终C2的IP地址
- 为进一步验证C2是否可用，该程序根据之前生成的域名再次生成长度为32的校验码，连接该C2，接收数据进行验证

```
Additional RRs: 10
> Queries
v Answers
  v 1a1f31761f.dontargetme.nl: type TXT, class IN
    Name: 1a1f31761f.dontargetme.nl
    Type: TXT (Text strings) (16)
    Class: IN (0x0001)
    Time to live: 1800 (30 minutes)
    Data length: 33
    TXT Length: 32
    TXT: 3519239A211D1808ED7DF5AD296F2856
  > Authoritative nameservers
  > Additional records
```

利用DNS的攻击—DGA(DarkCracks)

- 奇安信X实验室(XLab)于2024年6月捕获了一个使用DGA的恶意程序
- 该恶意程序的DGA算法较为简单
- DGA种子：将当前年月按照"%d%02d"进行格式化
- 伪随机算法：使用某字符串加密算法进行加密，最后根据http://%s.com进行标准化
- 以202408为例，产生的DGA域名为UVDFUgOAgjL.com

```
time(&timer);  
v0 = gmtime(&timer);  
sprintf(s, "%d%02d", (unsigned int)(v0->tm_year + 1900), (unsigned int)(v0->tm_mon + 1));  
return encstr(s);
```

DNS安全威胁及防范

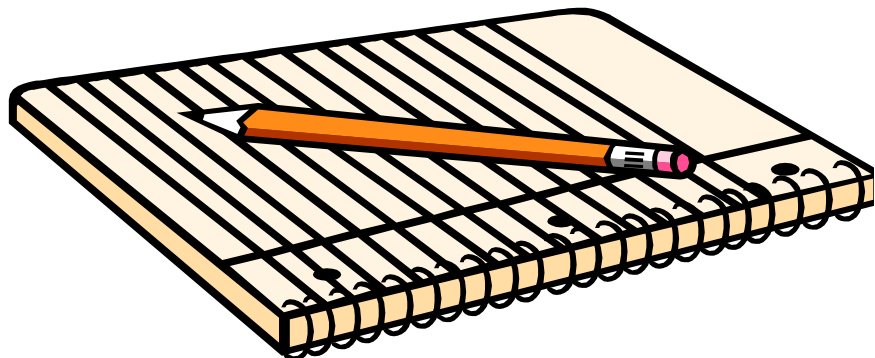
- DNS概述

- DNS工作流程

- DNS协议

- DNS安全威胁

- DNS安全防范



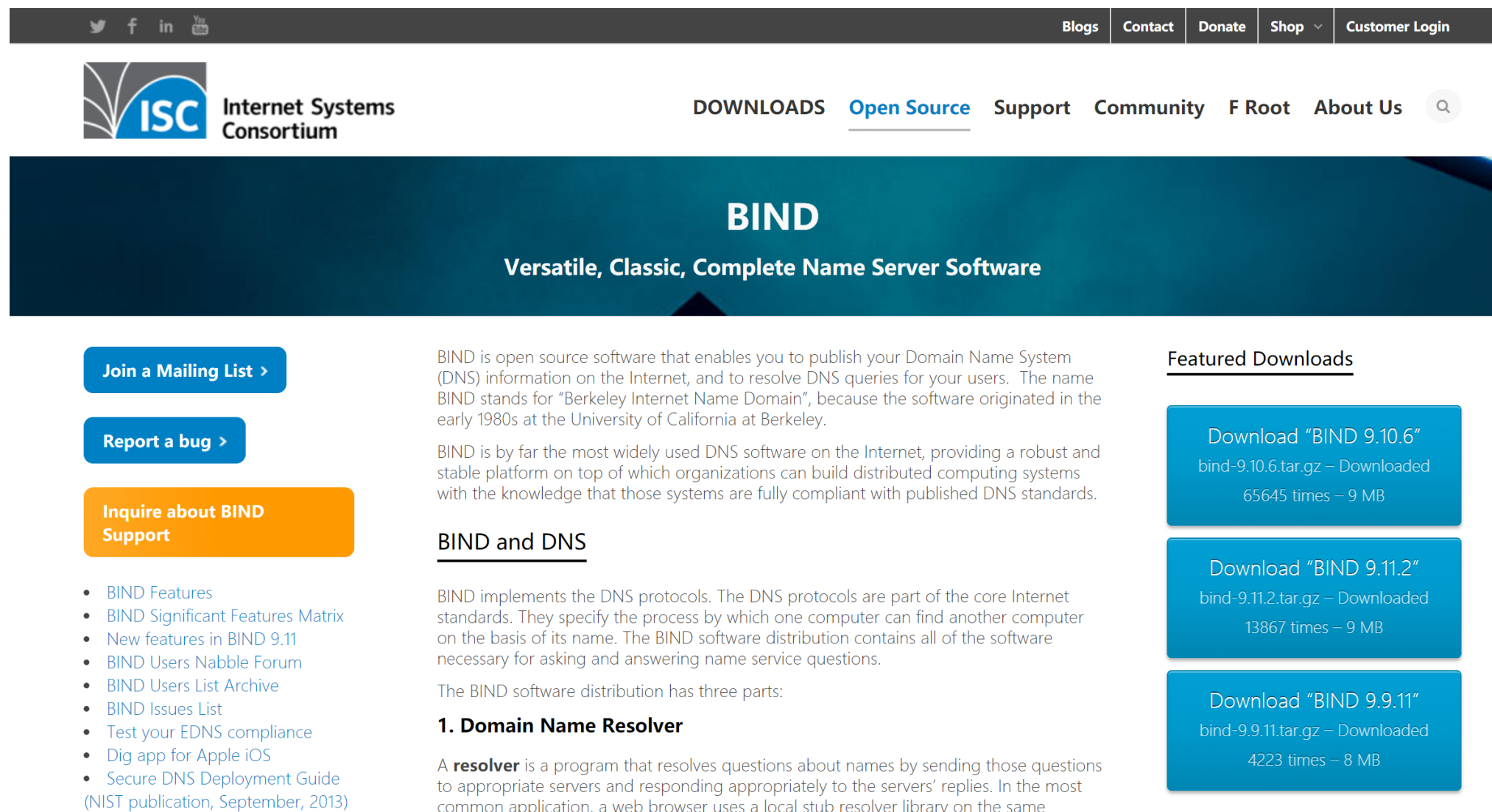
DNS安全防范

- DNS攻击的防范：
 - 应对DNS服务器面临的安全隐患主要依据以下两个准则：
 - 选择安全的没有缺陷的BIND版本
 - DNS服务器配置正确可靠

DNS安全防范

● BIND主要版本

- 1、BIND 4，1998年多数操作系统捆绑的是BIND4，但是现在已经被多数厂商抛弃。
- 2、BIND 8是曾经使用最广的版本，现在网络中的一部分DNS服务器仍在使用。
- 3、BIND 9最新版本，全部重新写过，免费（由商业公司资助），BIND9在2000年10月份推出，根据调查V9版本的BIND是最安全的。
- 4、BIND 10，2009年开始开发，2013年发布，Bundy。



The screenshot shows the BIND website homepage. At the top is a dark navigation bar with social media icons (Twitter, Facebook, LinkedIn, YouTube) on the left and links for Blogs, Contact, Donate, Shop, and Customer Login on the right. Below this is the ISC Internet Systems Consortium logo on the left and a row of links: DOWNLOADS, Open Source (underlined), Support, Community, F Root, and About Us, followed by a search icon. The main banner features the word "BIND" in large white letters, with the tagline "Versatile, Classic, Complete Name Server Software" below it. On the left side, there are three buttons: "Join a Mailing List >", "Report a bug >", and "Inquire about BIND Support". Below the "Inquire about BIND Support" button is a list of links: BIND Features, BIND Significant Features Matrix, New features in BIND 9.11, BIND Users Nabble Forum, BIND Users List Archive, BIND Issues List, Test your EDNS compliance, Dig app for Apple iOS, and Secure DNS Deployment Guide (NIST publication, September, 2013). The central content area contains a paragraph about BIND being open source software, followed by another paragraph stating it is the most widely used DNS software. Below this is a section titled "BIND and DNS" with a sub-section "1. Domain Name Resolver" and a paragraph explaining the role of a resolver. On the right side, there is a "Featured Downloads" section with three blue buttons, each containing download information for different versions of BIND (9.10.6, 9.11.2, and 9.9.11).

JOIN a Mailing List >

Report a bug >

Inquire about BIND Support

- BIND Features
- BIND Significant Features Matrix
- New features in BIND 9.11
- BIND Users Nabble Forum
- BIND Users List Archive
- BIND Issues List
- Test your EDNS compliance
- Dig app for Apple iOS
- Secure DNS Deployment Guide (NIST publication, September, 2013)

BIND is open source software that enables you to publish your Domain Name System (DNS) information on the Internet, and to resolve DNS queries for your users. The name BIND stands for "Berkeley Internet Name Domain", because the software originated in the early 1980s at the University of California at Berkeley.

BIND is by far the most widely used DNS software on the Internet, providing a robust and stable platform on top of which organizations can build distributed computing systems with the knowledge that those systems are fully compliant with published DNS standards.

BIND and DNS

BIND implements the DNS protocols. The DNS protocols are part of the core Internet standards. They specify the process by which one computer can find another computer on the basis of its name. The BIND software distribution contains all of the software necessary for asking and answering name service questions.

The BIND software distribution has three parts:

1. Domain Name Resolver

A **resolver** is a program that resolves questions about names by sending those questions to appropriate servers and responding appropriately to the servers' replies. In the most common application, a web browser uses a local stub resolver library on the same

Featured Downloads

Download "BIND 9.10.6"
bind-9.10.6.tar.gz – Downloaded
65645 times – 9 MB

Download "BIND 9.11.2"
bind-9.11.2.tar.gz – Downloaded
13867 times – 9 MB

Download "BIND 9.9.11"
bind-9.9.11.tar.gz – Downloaded
4223 times – 8 MB

DNS安全防范

- BIND安全配置

- 1、隔离DNS服务器

DNS服务器上不应该再运行其他服务，尤其是允许普通用户登录，减小攻击者利用其他服务漏洞攻击DNS服务器的概率。

- 2、为BIND创建chroot

chroot是指更改某个进程所能看到的根目录，即将某进程限制在指定的目录中，保证该进程只能对该目录及其子目录有所动作，从而保证整个服务器的安全。BIND9.x系列版本简化了chroot的创建步骤。

DNS安全防范

- BIND安全配置

- 3、隐藏BIND版本号，通过发送特殊的DNS查询包，DNS服务器会返回DNS的版本信息。如下图所示返回版本为9.2.4。

No.	Time	Source	Destination	Protocol	Info
73	70.580002	192.168.1.110	128.255.64.3	DNS	Standard query TXT version.bind
74	70.888402	128.255.64.3	192.168.1.110	DNS	Standard query response TXT

+	Frame 74 (104 bytes on wire, 104 bytes captured)
+	Ethernet II, Src: 00:1d:0f:54:fe:4c (00:1d:0f:54:fe:4c), Dst: LanTech_6f:26:57 (00:c0:26:6f:26:57)
+	Internet Protocol, Src: 128.255.64.3 (128.255.64.3), Dst: 192.168.1.110 (192.168.1.110)
+	User Datagram Protocol, Src Port: domain (53), Dst Port: 32770 (32770)
-	Domain Name System (response) - Transaction ID: 0x7777 +

DNS安全防范

- BIND安全配置

- 4、请求限制

DNS服务器响应任何人的任何请求是不安全的。限制DNS服务器的服务范围很重要，可以把许多入侵者拒之门外。修改BIND的配置文件/etc/named.conf,添加相应内容即可。

- 5、限制区传送

默认情况下BIND的区传送是全部开放的，如果没有限制，DNS服务器允许任何人进行区传送，那么网络架构中的主机名、主机ip地址表、路由器名及路由IP表，甚至包括各主机所在的位置和硬件配置信息等情况很容易被入侵者得到。因此需要对区传送进行必要的限制。

DNS安全防范

- BIND安全配置

- 6、关闭动态更新

最早设计DNS时，所有运行TCP/IP的计算机都是手工配置的。用特定的IP地址手工配置一台计算机时，它的A记录、PTR记录也要手工配置。随着DHCP的出现，IP地址动态分配，使手工更新A记录、PTR记录变得很难管理。

因此，在RFC2136中提出**DNS动态更新**，使得DNS客户端ip地址或名称出现更改时，可以利用DNS服务器注册和动态更新其资源记录。虽然DNS动态更新规定了怎样的系统才允许更新一台DNS服务器中的记录，但是DNS仍然可能受到威胁，比如攻击者利用IP欺骗，伪装成DNS服务器信任的主机对系统进行更新或者删减、增加、修改资源记录。

DNS安全防范—DNS加密协议

- 考虑信息安全三要素CIA：机密性、完整性、可用性
- 传统DNS：无机密性——明文传输；无完整性——简单信任、可被篡改
- DNSSEC：完整性——数字签名；无机密性
- DNSCrypt：无标准化——未提交过RFC
- DoT：DNS over TLS，CIA
- DoH：DNS over HTTPS，CIA
- DoQ：DNS over QUIC，CIA
- 国内常见加密DNS：阿里DNS、腾讯DNS、360DNS

DNS安全防范

- DNS其他加固措施
 - 事务签名（TSIG）技术
 - 配置DNS Flood Detector

DNS安全防范

- 事务签名（TSIG）技术
- DNS事务签名分为TSIG（Transaction Signature）与SIG0（SIGnature）。
- 对称式TSIG只有一组客户端和服务端共享密码；
- 非对称式SIG0，采用非对称密码算法，既有公钥又有私钥。如果客户端和服务端是完全信任的，可以采用TSIG，若是非完全信任，应采用SIG0。

DNS安全防范

- 事务签名(TSIG RFC 2845)
- 从BIND 8.2版本开始引入 TSIG 机制，
- 使用共享密钥 (Secret Key) 及单向杂凑函数(One-way hash function) 来提供讯息的验证和数据的完整性。
- 主要针对区带传输 (ZONE Transfer) 进行保护的作用，利用密码学编码方式为通讯传输信息加密以保证 DNS 讯息的安全，特别是响应与更新的讯息数据。也就是说在DNS服务器之间进行辖区传送时所提供保护的机制，以确保传输数据不被窃取及监听。

DNS安全防范

- SIG0是1999年3月，IBM公司的D. Eastlake 提出成为标准。
- 利用公钥机制为区域资料进行数字事物签章的动作，保证每次传输的 source record 具有可验证性与不可否认性。
- SIG0 是防止 DNS Spoofing 发生的有效技术。

DNS安全防范

- DNSSEC

- DNS欺骗是对目前网络应用的最大冲击，攻击者伪装成服务器提供假的域名和IP地址对应信息，将用户引导到错误的网站、或电子邮件丢失。
- 目前较新的BIND版本针对这一问题已经加入了许多改进方法：如发包源端口和事务ID的随机化。不过真正的解决方案，则有赖于数据包认证机制的建立和推广。
- DNSSEC就是试图解决这一类问题，BIND9已经加以设计和完成。DNSSEC引入了两个全新的资源记录类型：**KEY和SIG**，它们允许客户端和域名服务器对任何DNS数据的来源进行验证。

DNS安全防范

- DNSSEC主要依靠公钥技术对包含在DNS中的信息创建密码签名。密码签名通过计算一个哈希值来提供DNS中数据的完整性，并将该哈希值封装进行保护。私钥用来封装哈希值，公钥把哈希值解密出来，通过解密出的哈希值就可以判断数据的完整性。
- 当然DNSSEC也有一些缺点：产生和校验签名需要占用很多的CPU 时间，这些额外开销会影响服务器的性能；签名后的数据量很大，加重了互联网的负担。

DNS安全防范

- DNS Flood Detector
- DNS Flood Detector是针对DNS服务器的Flood攻击的检测工具，用于侦测恶意的使用DNS的查询功能。它会监控向服务器查询名称解析的数量，分成守护进程（daemon）和后台（bindsnap）模式。守护进程模式会发出警示（/var/log/message）。Bindsnap模式可以得到接近实时的查询状态。

思考

DNS加密协议一定比传统DNS协议更合适吗？

- 考虑资源占用、兼容性与实现成本，在IoT设备上使用传统DNS协议更合适

DoH等协议在增强了DNS的安全性的同时，是否有其他问题？

- DoH有效防范了对DNS的攻击，但反而增强了利用DNS的攻击
- DNS隧道更加难以被检测，通信内容被HTTPS等协议加密，DoH流量相比于DNS流量更难被追踪与分析
- Kaspersky在2020年就已经发现APT组织Oilrig通过DoH隧道实现攻击

问题和讨论